

PCI Detailed Vulnerability Report

Prepared for: Trainpetdog Limited

Scan Date: 06/23/2014 04:27:09

Generated: 06/24/2014 12:40:05



Table of Contents

Part 1. Scan Information	1
Part 2. Vulnerability Details	1
Host IP: 75.126.159.2 (75.126.159.2-static.reverse.softlayer.com).....	1
Host IP: 75.126.159.3 (75.126.159.3-static.reverse.softlayer.com).....	36

Part 1. Scan Information			
Scan Customer Company:	Trainpetdog Limited		
ASV Company:	Clone Systems, Inc.		
Date scan was completed:	06/23/2014 04:27:09	Scan expiration date:	09/21/2014 04:27:09

Part 2. Vulnerability Details			
75.126.159.2 (75.126.159.2-static.reverse.softlayer.com)			
IP Address	Severity Level	Compliance Status	Details
75.126.159.2	Medium	Fail	Application: smtp Port: 25 Protocol: tcp VATID: 57582 Synopsis : The SSL certificate chain for this service ends in an unrecognized self-signed certificate. Description : The X.509 certificate chain for this service is not signed by a recognized certificate authority. If the remote host is a public host in production, this nullifies the use of SSL as anyone could establish a man-in-the-middle attack against the remote host. Note that this plugin does not check for certificate chains that end in a certificate that is not self-signed, but is signed by an unrecognized certificate authority. Solution : Purchase or generate a proper certificate for this service. CVSS Base Score : 6.4 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:N) Plugin output : The following certificate was found at the top of the certificate chain sent by the remote host, but is self-signed and was not found in the list of known certificate authorities :
75.126.159.2	Medium	Fail	Application: smtp Port: 25 Protocol: tcp VATID: 57582 Synopsis : The SSL certificate chain for this service ends in an unrecognized self-signed certificate.

			Description : The X.509 certificate chain for this service is not signed by a recognized certificate authority. If the remote host is a public host in production, this nullifies the use of SSL as anyone could establish a man-in-the-middle attack against the remote host. Note that this plugin does not check for certificate chains that end in a certificate that is not self-signed, but is signed by an unrecognized certificate authority. Solution : Purchase or generate a proper certificate for this service. CVSS Base Score : 6.4 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:N) Plugin output : The following certificate was found at the top of the certificate chain sent by the remote host, but is self-signed and was not found in the list of known certificate authorities :
75.126.159.2	Medium	Fail	Application: smtp Port: 25 Protocol: tcp VATID: 57582 Synopsis : The SSL certificate chain for this service ends in an unrecognized self-signed certificate. Description : The X.509 certificate chain for this service is not signed by a recognized certificate authority. If the remote host is a public host in production, this nullifies the use of SSL as anyone could establish a man-in-the-middle attack against the remote host. Note that this plugin does not check for certificate chains that end in a certificate that is not self-signed, but is signed by an unrecognized certificate authority. Solution : Purchase or generate a proper certificate for this service. CVSS Base Score : 6.4 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:N) Plugin output : The following certificate was found at the top of the certificate

			chain sent by the remote host, but is self-signed and was not found in the list of known certificate authorities :
75.126.159.2	Medium	Fail	Application: smtp Port: 25 Protocol: tcp VATID: 57582 Synopsis : The SSL certificate chain for this service ends in an unrecognized self-signed certificate. Description : The X.509 certificate chain for this service is not signed by a recognized certificate authority. If the remote host is a public host in production, this nullifies the use of SSL as anyone could establish a man-in-the-middle attack against the remote host. Note that this plugin does not check for certificate chains that end in a certificate that is not self-signed, but is signed by an unrecognized certificate authority. Solution : Purchase or generate a proper certificate for this service. CVSS Base Score : 6.4 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:N) Plugin output : The following certificate was found at the top of the certificate chain sent by the remote host, but is self-signed and was not found in the list of known certificate authorities :
75.126.159.2	Medium	Fail	Application: smtp Port: 25 Protocol: tcp VATID: 57582 Synopsis : The SSL certificate chain for this service ends in an unrecognized self-signed certificate. Description : The X.509 certificate chain for this service is not signed by a recognized certificate authority. If the remote host is a public host in production, this nullifies the use of SSL as anyone could establish a man-in-the-middle attack against the remote host. Note that this plugin does not check for certificate chains that end in a certificate that is not self-signed, but is signed by an unrecognized certificate authority.

			Solution : Purchase or generate a proper certificate for this service. CVSS Base Score : 6.4 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:N) Plugin output : The following certificate was found at the top of the certificate chain sent by the remote host, but is self-signed and was not found in the list of known certificate authorities :
75.126.159.2	Medium	Fail	Application: smtp Port: 25 Protocol: tcp VATID: 51192 Synopsis : The SSL certificate for this service cannot be trusted. Description : The server's X.509 certificate does not have a signature from a known public certificate authority. This situation can occur in three different ways, each of which results in a break in the chain below which certificates cannot be trusted. First, the top of the certificate chain sent by the server might not be descended from a known public certificate authority. This can occur either when the top of the chain is an unrecognized, self-signed certificate, or when intermediate certificates are missing that would connect the top of the certificate chain to a known public certificate authority. Second, the certificate chain may contain a certificate that is not valid at the time of the scan. This can occur either when the scan occurs before one of the certificate's 'notBefore' dates, or after one of the certificate's 'notAfter' dates. Third, the certificate chain may contain a signature that either didn't match the certificate's information, or could not be verified. Bad signatures can be fixed by getting the certificate with the bad signature to be re-signed by its issuer. Signatures that could not be verified are the result of the certificate's issuer using a signing algorithm that Nessus either does not support or does not recognize. If the remote host is a public host in production, any break in the chain makes it more difficult for users to verify the authenticity and identity of the web server. This could make it easier to carry out man-in-the-middle attacks against the remote host.

			Solution : Purchase or generate a proper certificate for this service. CVSS Base Score : 6.4 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:N) Plugin output : The following certificate was at the top of the certificate chain sent by the remote host, but is signed by an unknown certificate authority :
75.126.159.2	Medium	Fail	Application: smtp Port: 25 Protocol: tcp VATID: 51192 Synopsis : The SSL certificate for this service cannot be trusted. Description : The server's X.509 certificate does not have a signature from a known public certificate authority. This situation can occur in three different ways, each of which results in a break in the chain below which certificates cannot be trusted. First, the top of the certificate chain sent by the server might not be descended from a known public certificate authority. This can occur either when the top of the chain is an unrecognized, self-signed certificate, or when intermediate certificates are missing that would connect the top of the certificate chain to a known public certificate authority. Second, the certificate chain may contain a certificate that is not valid at the time of the scan. This can occur either when the scan occurs before one of the certificate's 'notBefore' dates, or after one of the certificate's 'notAfter' dates. Third, the certificate chain may contain a signature that either didn't match the certificate's information, or could not be verified. Bad signatures can be fixed by getting the certificate with the bad signature to be re-signed by its issuer. Signatures that could not be verified are the result of the certificate's issuer using a signing algorithm that Nessus either does not support or does not recognize. If the remote host is a public host in production, any break in the chain makes it more difficult for users to verify the authenticity and identity of the web server. This could make it easier to carry out man-in-the-middle attacks against the remote host. Solution :

			Purchase or generate a proper certificate for this service. CVSS Base Score : 6.4 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:N) Plugin output : The following certificate was at the top of the certificate chain sent by the remote host, but is signed by an unknown certificate authority :
75.126.159.2	Medium	Fail	Application: http Port: 80 Protocol: tcp VATID: 11229 Synopsis : The remote web server contains a PHP script that is prone to an information disclosure attack. Description : Many PHP installation tutorials instruct the user to create a PHP file that calls the PHP function 'phpinfo()' for debugging purposes. Various PHP applications may also include such a file. By accessing such a file, a remote attacker can discover a large amount of information about the remote web server, including : - The username of the user who installed PHP and if they are a SUDO user. - The IP address of the host. - The version of the operating system. - The web server version. - The root directory of the web server. - Configuration information about the remote PHP installation. Solution : Remove the affected file(s). CVSS Base Score : 5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N) Plugin output : Nessus discovered the following URL that calls phpinfo() :

			- http://75.126.159.2-static.reverse.softlayer.com/info.php
75.126.159.2	Medium	Fail	Application: http Port: 80 Protocol: tcp VATID: 11229 Synopsis : The remote web server contains a PHP script that is prone to an information disclosure attack. Description : Many PHP installation tutorials instruct the user to create a PHP file that calls the PHP function 'phpinfo()' for debugging purposes. Various PHP applications may also include such a file. By accessing such a file, a remote attacker can discover a large amount of information about the remote web server, including : - The username of the user who installed PHP and if they are a SUDO user. - The IP address of the host. - The version of the operating system. - The web server version. - The root directory of the web server. - Configuration information about the remote PHP installation. Solution : Remove the affected file(s). CVSS Base Score : 5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N) Plugin output : Nessus discovered the following URL that calls phpinfo() : - http://75.126.159.2-static.reverse.softlayer.com/info.php
75.126.159.2	Medium	Fail	Application: http Port: 80 Protocol: tcp VATID: 11229 Synopsis : The remote web server contains a PHP script that is prone to an information disclosure attack.

			Description : Many PHP installation tutorials instruct the user to create a PHP file that calls the PHP function 'phpinfo()' for debugging purposes. Various PHP applications may also include such a file. By accessing such a file, a remote attacker can discover a large amount of information about the remote web server, including : - The username of the user who installed PHP and if they are a SUDO user. - The IP address of the host. - The version of the operating system. - The web server version. - The root directory of the web server. - Configuration information about the remote PHP installation. Solution : Remove the affected file(s). CVSS Base Score : 5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N) Plugin output : Nessus discovered the following URL that calls phpinfo() : - http://75.126.159.2-static.reverse.softlayer.com/info.php
75.126.159.2	Medium	Fail	Application: http Port: 80 Protocol: tcp VATID: 57640 Synopsis : The remote web application discloses path information. Description : At least one web application hosted on the remote web server discloses the physical path to its directories when a malformed request is sent to it. Leaking this kind of information may help an attacker fine-tune attacks against the application and its backend. Solution :

			Filter error messages containing path information. CVSS Base Score : 5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N) Plugin output : The request GET /manual/en/howto/ssi.html HTTP/1.1\r Host: 75.126.159.2-static.reverse.softlayer.com\r Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1\r Accept-Language: en\r Connection: Close\r Cookie: <!--#include file="nessus181570537.html"-->\r User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r Pragma: no-cache\r Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*\r \r produces the following path information : something else that you can do with the <code>exec</code> element. You can actually have SSI execute a command using the shell (<code>/bin/sh</code>, to be precise - or the DOS shell, if you're on Win32). The following, for example, will give you a directory listing.</p>
75.126.159.2	Medium	Fail	Application: http Port: 80 Protocol: tcp VATID: 57640 Synopsis : The remote web application discloses path information. Description : At least one web application hosted on the remote web server discloses the physical path to its directories when a malformed request is sent to it. Leaking this kind of information may help an attacker fine-tune attacks against the application and its backend. Solution : Filter error messages containing path information. CVSS Base Score : 5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N) Plugin output : The request GET /manual/en/howto/ssi.html HTTP/1.1\r Host: 75.126.159.2-static.reverse.softlayer.com\r

			Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1\r Accept-Language: en\r Connection: Close\r Cookie: <!--#include file="nessus181570537.html"-->\r User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r Pragma: no-cache\r Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*\r \r produces the following path information : something else that you can do with the <code><code>exec</code></code> element. You can actually have SSI execute a command using the shell (<code><code>/bin/sh</code></code>, to be precise - or the DOS shell, if you're on Win32). The following, for example, will give you a directory listing.</p>
75.126.159.2	Medium	Fail	Application: smtp Port: 25 Protocol: tcp VATID: 26928 Synopsis : The remote service supports the use of weak SSL ciphers. Description : The remote host supports the use of SSL ciphers that offer weak encryption. Note: This is considerably easier to exploit if the attacker is on the same physical network. See also : http://www.openssl.org/docs/apps/ciphers.html Solution : Reconfigure the affected application, if possible to avoid the use of weak ciphers. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:P/I:N/A:N) Plugin output : Here is the list of weak SSL ciphers supported by the remote server : Low Strength Ciphers (< 56-bit key) SSLv3 EXP-ADH-DES-CBC-SHA Kx=DH(512) Au=None Enc=DES-CBC(40) Mac=SHA1 export

			EXP-ADH-RC4-MD5 Kx=DH(512) Au=None Enc=RC4(40) Mac=MD5 export EXP-EDH-RSA-DES-CBC-SHA Kx=DH(512) Au=RSA Enc=DES-CBC(40) Mac=SHA1 export EXP-DES-CBC-SHA Kx=RSA(512) Au=RSA Enc=DES-CBC(40) Mac=SHA1 export EXP-RC2-CBC-MD5 Kx=RSA(512) Au=RSA Enc=RC2(40) Mac=MD5 export EXP-RC4-MD5 Kx=RSA(512) Au=RSA Enc=RC4(40) Mac=MD5 export TLSv1 EXP-EDH-RSA-DES-CBC-SHA Kx=DH(512) Au=RSA Enc=DES-CBC(40) Mac=SHA1 export EXP-ADH-DES-CBC-SHA Kx=DH(512) Au=None Enc=DES-CBC(40) Mac=SHA1 export EXP-ADH-RC4-MD5 Kx=DH(512) Au=None Enc=RC4(40) Mac=MD5 export EXP-DES-CBC-SHA Kx=RSA(512) Au=RSA Enc=DES-CBC(40) Mac=SHA1 export EXP-RC2-CBC-MD5 Kx=RSA(512) Au=RSA Enc=RC2-CBC(40) Mac=MD5 export EXP-RC4-MD5 Kx=RSA(512) Au=RSA Enc=RC4(40) Mac=MD5 export The fields above are : {OpenSSL ciphername} Kx={key exchange} Au={authentication} Enc={symmetric encryption method} Mac={message authentication code} {export flag} Other references : CWE:327, CWE:326, CWE:753, CWE:803, CWE:720
75.126.159.2	Medium	Fail	Application: smtp Port: 25 Protocol: tcp VATID: 42873 Synopsis : The remote service supports the use of medium strength SSL ciphers. Description : The remote host supports the use of SSL ciphers that offer medium strength encryption, which we currently regard as those with key lengths at least 56 bits and less than 112 bits. Note: This is considerably easier to exploit if the attacker is on the same physical network. Solution :

			Reconfigure the affected application if possible to avoid use of medium strength ciphers. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:P/I:N/A:N) Plugin output : Here is the list of medium strength SSL ciphers supported by the remote server : Medium Strength Ciphers (>= 56-bit and < 112-bit key) SSLv3 <table><tr><td>ADH-DES-CBC-SHA</td><td>Kx=DH</td><td>Au=None</td><td>Enc=DES-CBC(56)</td><td>Mac=SHA1</td></tr><tr><td>EDH-RSA-DES-CBC-SHA</td><td>Kx=DH</td><td>Au=RSA</td><td>Enc=DES-CBC(56)</td><td>Mac=SHA1</td></tr><tr><td>DES-CBC-SHA</td><td>Kx=RSA</td><td>Au=RSA</td><td>Enc=DES-CBC(56)</td><td>Mac=SHA1</td></tr></table> TLSv1 <table><tr><td>EDH-RSA-DES-CBC-SHA</td><td>Kx=DH</td><td>Au=RSA</td><td>Enc=DES-CBC(56)</td><td>Mac=SHA1</td></tr><tr><td>ADH-DES-CBC-SHA</td><td>Kx=DH</td><td>Au=None</td><td>Enc=DES-CBC(56)</td><td>Mac=SHA1</td></tr><tr><td>DES-CBC-SHA</td><td>Kx=RSA</td><td>Au=RSA</td><td>Enc=DES-CBC(56)</td><td>Mac=SHA1</td></tr></table> The fields above are : {OpenSSL ciphername} Kx={key exchange} Au={authentication} Enc={symmetric encryption method} Mac={message authentication code} {export flag}	ADH-DES-CBC-SHA	Kx=DH	Au=None	Enc=DES-CBC(56)	Mac=SHA1	EDH-RSA-DES-CBC-SHA	Kx=DH	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1	DES-CBC-SHA	Kx=RSA	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1	EDH-RSA-DES-CBC-SHA	Kx=DH	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1	ADH-DES-CBC-SHA	Kx=DH	Au=None	Enc=DES-CBC(56)	Mac=SHA1	DES-CBC-SHA	Kx=RSA	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1
ADH-DES-CBC-SHA	Kx=DH	Au=None	Enc=DES-CBC(56)	Mac=SHA1																													
EDH-RSA-DES-CBC-SHA	Kx=DH	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1																													
DES-CBC-SHA	Kx=RSA	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1																													
EDH-RSA-DES-CBC-SHA	Kx=DH	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1																													
ADH-DES-CBC-SHA	Kx=DH	Au=None	Enc=DES-CBC(56)	Mac=SHA1																													
DES-CBC-SHA	Kx=RSA	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1																													
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 31705 Synopsis : The remote service supports the use of anonymous SSL ciphers. Description : The remote host supports the use of anonymous SSL ciphers. While this enables an administrator to set up a service that encrypts traffic without having to generate and configure SSL certificates, it offers no way to verify the remote host's identity and renders the service vulnerable to a man-in-the-middle attack. Note: This is considerably easier to exploit if the attacker is on the same physical network. See also : http://www.openssl.org/docs/apps/ciphers.html																														

Solution :

Reconfigure the affected application if possible to avoid use of weak ciphers.

CVSS Base Score : 2.6

(CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

CVSS Temporal Score : 2.3

(CVSS2#E:ND/RL:OF/RC:C)

Public Exploit Available : true

Plugin output :

Here is the list of SSL anonymous ciphers supported by the remote server :

Low Strength Ciphers (< 56-bit key)

SSLv3

EXP-ADH-DES-CBC-SHA	Kx=DH(512)	Au=None	Enc=DES-CBC(40)	Mac=SHA1
---------------------	------------	---------	-----------------	----------

export

EXP-ADH-RC4-MD5	Kx=DH(512)	Au=None	Enc=RC4(40)	Mac=MD5
-----------------	------------	---------	-------------	---------

export

TLSv1

EXP-ADH-DES-CBC-SHA	Kx=DH(512)	Au=None	Enc=DES-CBC(40)	Mac=SHA1
---------------------	------------	---------	-----------------	----------

export

EXP-ADH-RC4-MD5	Kx=DH(512)	Au=None	Enc=RC4(40)	Mac=MD5
-----------------	------------	---------	-------------	---------

export

Medium Strength Ciphers (>= 56-bit and < 112-bit key)

SSLv3

ADH-DES-CBC-SHA	Kx=DH	Au=None	Enc=DES-CBC(56)	Mac=SHA1
-----------------	-------	---------	-----------------	----------

TLSv1

ADH-DES-CBC-SHA	Kx=DH	Au=None	Enc=DES-CBC(56)	Mac=SHA1
-----------------	-------	---------	-----------------	----------

High Strength Ciphers (>= 112-bit key)

SSLv3

ADH-DES-CBC3-SHA	Kx=DH	Au=None	Enc=3DES-CBC(168)	Mac=SHA1
ADH-RC4-MD5	Kx=DH	Au=None	Enc=RC4(128)	Mac=MD5

TLSv1

ADH-DES-CBC3-SHA	Kx=DH	Au=None	Enc=3DES-CBC(168)	Mac=SHA1
ADH-AES128-SHA	Kx=DH	Au=None	Enc=AES-CBC(128)	Mac=SHA1
ADH-AES256-SHA	Kx=DH	Au=None	Enc=AES-CBC(256)	Mac=SHA1
ADH-CAMELLIA128-SHA	Kx=DH	Au=None	Enc=Camellia-CBC(128)	Mac=SHA1

ADH-CAMELLIA256-SHA	Kx=DH	Au=None	Enc=Camellia-CBC(256)	Mac=SHA1
---------------------	-------	---------	-----------------------	----------

ADH-RC4-MD5	Kx=DH	Au=None	Enc=RC4(128)	Mac=MD5
-------------	-------	---------	--------------	---------

			ADH-SEED-SHA Kx=DH Au=None Enc=SEED-CBC(128) Mac=SHA1 AECDH-DES-CBC3-SHA Kx=ECDH Au=None Enc=3DES-CBC(168) Mac=SHA1 AECDH-AES128-SHA Kx=ECDH Au=None Enc=AES-CBC(128) Mac=SHA1 AECDH-AES256-SHA Kx=ECDH Au=None Enc=AES-CBC(256) Mac=SHA1 AECDH-RC4-SHA Kx=ECDH Au=None Enc=RC4(128) Mac=SHA1 The fields above are : {OpenSSL ciphername} Kx={key exchange} Au={authentication} Enc={symmetric encryption method} Mac={message authentication code} {export flag} CVE : CVE-2007-1858 BID : 28482 Other references : OSVDB:34882
75.126.159.2	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 34324 Synopsis : Authentication credentials might be intercepted. Description : The remote FTP server allows the user's name and password to be transmitted in clear text, which could be intercepted by a network sniffer or a man-in-the-middle attack. Solution : Switch to SFTP (part of the SSH suite) or FTPS (FTP over SSL/TLS). In the latter case, configure the server so that control connections are encrypted. CVSS Base Score : 2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N) Plugin output : This FTP server does not support 'AUTH TLS'. Other references : CWE:522, CWE:523
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 14772 Synopsis :

			This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to identify common services which might have been missed because of a network problem. Solution : See below Plugin output : A SMTP server is running on this port
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 11421 Synopsis : It is possible to fingerprint the remote mail server. Description : smtpscan is a SMTP fingerprinting tool written by Julien Bordet It identifies the remote mail server even if the banners were changed. Solution : n/a Plugin output : smtpscan was not able to reliably identify this server. It might be: Postfix 1.1.11 Postfix Minesweeper 100 Postfix 2.0.13-3 (Mandrake Linux) Postfix 2.0.6 Postfix The fingerprint differs from these known signatures on 1 point(s) If you known precisely what it is, please send this fingerprint to smtp-signatures@nessus.org : :503:501:501:250:501:250:554:502:502:502:502:502:250:250 Postfix (Debian/GNU)
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 10263 Synopsis :

			An SMTP server is listening on the remote port. Description : The remote host is running a mail (SMTP) server on this port. Since SMTP servers are the targets of spammers, it is recommended you disable it if you do not use it. Solution : Disable this service if you do not use it, or filter incoming traffic to this port. Plugin output : Remote SMTP server banner : 220 mail.srvswbnet ESMTP Postfix (Debian/GNU)
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 42088 Synopsis : The remote mail service supports encrypting traffic. Description : The remote SMTP service supports the use of the 'STARTTLS' command to switch from a plaintext to an encrypted communications channel. See also : http://en.wikipedia.org/wiki/STARTTLS http://tools.ietf.org/html/rfc2487 Solution : n/a Plugin output : Here is the SMTP service's SSL certificate that Nessus was able to collect after sending a 'STARTTLS' command : ----- snip ----- Subject Name: Common Name: srvswbnet Issuer Name:

			Common Name: srvswnet Serial Number: 00 B8 B4 83 95 7E 0E 14 EC Version: 1 Signature Algorithm: SHA-1 With RSA Encryption Not Valid Before: Sep 14 12:41:32 2011 GMT Not Valid After: Sep 11 12:41:32 2021 GMT Public Key Info: Algorithm: RSA Encryption Key Length: 1024 bits Public Key: 00 C0 82 DB E5 7F 8A 4B 19 18 8E BD 1A 61 F6 30 A9 FD BD 64 19 22 B5 DE 72 FC E0 6C 2F A1 78 E9 F7 13 09 89 7B DE 2E B5 F1 27 DF 7F 6B 55 9F 29 9D 92 2A 6C 69 06 82 E2 92 E4 76 8C 34 8D 59 61 31 AB 26 4F 45 45 C7 7E 5A 44 CE F2 14 2F AE 31 92 D3 3C DE 75 DE 39 4F 2F 30 88 F3 BA 8C 22 7E BE B5 DF F1 15 A0 4B 80 51 E4 C8 2E 82 E5 E1 61 89 34 92 3B 22 35 DA C5 58 02 6B A7 53 36 5B D8 E3 Exponent: 01 00 01 Signature Length: 128 bytes / 1024 bits Signature: 00 61 C9 56 06 51 B9 B3 31 30 B0 39 19 9F 72 F1 A9 FA A0 78 B7 FB 21 7B FC A7 9D BB 91 B6 B8 E0 7C 29 A5 1E 4C 46 C5 CF 55 4E F8 63 57 30 54 46 3A D2 37 E0 9B 0D CD 7B 34 89 C7 79 2A D5 B2 73 B7 6A 1C 7A E2 25 B3 6D A7 37 D3 D8 39 2F 64 85 2B 32 69 93 71 91 81 AC CE E7 24 36 06 18 39 C8 A0 5C 14 66 FF F8 A3 1C 15 AB 70 D1 EF B9 60 5B EA 88 A2 EA CB CE 50 55 3D 79 01 2C 5E 30 32 88 4D ----- snip -----
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 56984 Synopsis : The remote service encrypts communications. Description : This script detects which SSL and TLS versions are supported by the remote service for encrypting communications. Solution : n/a Plugin output :

			This port supports SSLv3/TLSv1.0/TLSv1.1/TLSv1.2.
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 10863 Synopsis : This plugin displays the SSL certificate. Description : This plugin connects to every SSL-related port and attempts to extract and dump the X.509 certificate. Solution : n/a Plugin output : Subject Name: Common Name: srvswnet Issuer Name: Common Name: srvswnet Serial Number: 00 B8 B4 83 95 7E 0E 14 EC Version: 1 Signature Algorithm: SHA-1 With RSA Encryption Not Valid Before: Sep 14 12:41:32 2011 GMT Not Valid After: Sep 11 12:41:32 2021 GMT Public Key Info: Algorithm: RSA Encryption Key Length: 1024 bits Public Key: 00 C0 82 DB E5 7F 8A 4B 19 18 8E BD 1A 61 F6 30 A9 FD BD 64 19 22 B5 DE 72 FC E0 6C 2F A1 78 E9 F7 13 09 89 7B DE 2E B5 F1 27 DF 7F 6B 55 9F 29 9D 92 2A 6C 69 06 82 E2 92 E4 76 8C 34 8D 59 61 31 AB 26 4F 45 45 C7 7E 5A 44 CE F2 14 2F AE 31 92 D3 3C DE 75 DE 39 4F 2F 30 88 F3 BA 8C 22 7E BE B5 DF F1 15 A0 4B 80 51 E4 C8 2E 82 E5 E1 61 89 34 92 3B 22 35 DA C5 58 02 6B A7 53 36 5B D8 E3 Exponent: 01 00 01 Signature Length: 128 bytes / 1024 bits Signature: 00 61 C9 56 06 51 B9 B3 31 30 B0 39 19 9F 72 F1 A9 FA A0 78 B7 FB 21 7B FC A7 9D BB 91 B6 B8 E0 7C 29 A5 1E 4C 46 C5 CF

			55 4E F8 63 57 30 54 46 3A D2 37 E0 9B 0D CD 7B 34 89 C7 79 2A D5 B2 73 B7 6A 1C 7A E2 25 B3 6D A7 37 D3 D8 39 2F 64 85 2B 32 69 93 71 91 81 AC CE E7 24 36 06 18 39 C8 A0 5C 14 66 FF F8 A3 1C 15 AB 70 D1 EF B9 60 5B EA 88 A2 EA CB CE 50 55 3D 79 01 2C 5E 30 32 88 4D
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 50845 Synopsis : The remote service appears to use OpenSSL to encrypt traffic. Description : Based on its response to a TLS request with a specially crafted server name extension, it seems that the remote service is using the OpenSSL library to encrypt traffic. Note that this plugin can only detect OpenSSL implementations that have enabled support for TLS extensions (RFC 4366). See also : http://www.openssl.org Solution : n/a
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 62563 Synopsis : The remote service supports one or more compression methods for SSL connections. Description : This script detects which compression methods are supported by the remote service for SSL connections. See also : http://www.iana.org/assignments/comp-meth-ids/comp-meth-ids.xml http://tools.ietf.org/html/rfc3749 http://tools.ietf.org/html/rfc3943 http://tools.ietf.org/html/rfc5246 Solution : n/a

			Plugin output : Nessus was able to confirm that the following compression methods are supported by the target : NULL (0x00) DEFLATE (0x01)
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 45410 Synopsis : The SSL certificate commonName does not match the host name. Description : This service presents an SSL certificate for which the 'commonName' (CN) does not match the host name on which the service listens. Solution : If the machine has several names, make sure that users connect to the service through the DNS host name that matches the common name in the certificate. Plugin output : The host name known by Nessus is : 75.126.159.2-static.reverse.softlayer.com The Common Name in the certificate is : srvswnet
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 21643 Synopsis : The remote service encrypts communications using SSL. Description : This script detects which SSL ciphers are supported by the remote service for encrypting communications. See also : http://www.openssl.org/docs/apps/ciphers.html

Solution :

n/a

Plugin output :

Here is the list of SSL ciphers supported by the remote server :

Low Strength Ciphers (< 56-bit key)

SSLv3

EXP-ADH-DES-CBC-SHA	Kx=DH(512)	Au=None	Enc=DES-CBC(40)	Mac=SHA1
export				
EXP-ADH-RC4-MD5	Kx=DH(512)	Au=None	Enc=RC4(40)	Mac=MD5
export				
EXP-EDH-RSA-DES-CBC-SHA	Kx=DH(512)	Au=RSA	Enc=DES-CBC(40)	Mac=SHA1
export				
EXP-DES-CBC-SHA	Kx=RSA(512)	Au=RSA	Enc=DES-CBC(40)	Mac=SHA1
export				
EXP-RC2-CBC-MD5	Kx=RSA(512)	Au=RSA	Enc=RC2(40)	Mac=MD5
export				
EXP-RC4-MD5	Kx=RSA(512)	Au=RSA	Enc=RC4(40)	Mac=MD5
export				

TLSv1

EXP-EDH-RSA-DES-CBC-SHA	Kx=DH(512)	Au=RSA	Enc=DES-CBC(40)	Mac=SHA1
export				
EXP-ADH-DES-CBC-SHA	Kx=DH(512)	Au=None	Enc=DES-CBC(40)	Mac=SHA1
export				
EXP-ADH-RC4-MD5	Kx=DH(512)	Au=None	Enc=RC4(40)	Mac=MD5
export				
EXP-DES-CBC-SHA	Kx=RSA(512)	Au=RSA	Enc=DES-CBC(40)	Mac=SHA1
export				
EXP-RC2-CBC-MD5	Kx=RSA(512)	Au=RSA	Enc=RC2-CBC(40)	Mac=MD5
export				
EXP-RC4-MD5	Kx=RSA(512)	Au=RSA	Enc=RC4(40)	Mac=MD5
export				

Medium Strength Ciphers (>= 56-bit and < 112-bit key)

SSLv3

ADH-DES-CBC-SHA	Kx=DH	Au=None	Enc=DES-CBC(56)	Mac=SHA1
EDH-RSA-DES-CBC-SHA	Kx=DH	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1
DES-CBC-SHA	Kx=RSA	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1

TLSv1

EDH-RSA-DES-CBC-SHA	Kx=DH	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1
ADH-DES-CBC-SHA	Kx=DH	Au=None	Enc=DES-CBC(56)	Mac=SHA1
DES-CBC-SHA	Kx=RSA	Au=RSA	Enc=DES-CBC(56)	Mac=SHA1

High Strength Ciphers (>= 112-bit key)

SSLv3

ADH-DES-CBC3-SHA	Kx=DH	Au=None	Enc=3DES-CBC(168)	Mac=SHA1
ADH-RC4-MD5	Kx=DH	Au=None	Enc=RC4(128)	Mac=MD5
EDH-RSA-DES-CBC3-SHA	Kx=DH	Au=RSA	Enc=3DES(168)	Mac=SHA1
DES-CBC3-SHA	Kx=RSA	Au=RSA	Enc=3DES(168)	Mac=SHA1
RC4-MD5	Kx=RSA	Au=RSA	Enc=RC4(128)	Mac=MD5
RC4-SHA	Kx=RSA	Au=RSA	Enc=RC4(128)	Mac=SHA1

TLSv1

EDH-RSA-DES-CBC3-SHA	Kx=DH	Au=RSA	Enc=3DES-CBC(168)	Mac=SHA1
----------------------	-------	--------	-------------------	----------

DHE-RSA-AES128-SHA	Kx=DH	Au=RSA	Enc=AES-CBC(128)	Mac=SHA1
DHE-RSA-AES256-SHA	Kx=DH	Au=RSA	Enc=AES-CBC(256)	Mac=SHA1
DHE-RSA-CAMELLIA128-SHA	Kx=DH	Au=RSA	Enc=Camellia-CBC(128)	Mac=SHA1
DHE-RSA-CAMELLIA256-SHA	Kx=DH	Au=RSA	Enc=Camellia-CBC(256)	Mac=SHA1

DHE-RSA-SEED-SHA	Kx=DH	Au=RSA	Enc=SEED-CBC(128)	Mac=SHA1
ADH-DES-CBC3-SHA	Kx=DH	Au=None	Enc=3DES-CBC(168)	Mac=SHA1
ADH-AES128-SHA	Kx=DH	Au=None	Enc=AES-CBC(128)	Mac=SHA1
ADH-AES256-SHA	Kx=DH	Au=None	Enc=AES-CBC(256)	Mac=SHA1
ADH-CAMELLIA128-SHA	Kx=DH	Au=None	Enc=Camellia-CBC(128)	Mac=SHA1
ADH-CAMELLIA256-SHA	Kx=DH	Au=None	Enc=Camellia-CBC(256)	Mac=SHA1

ADH-RC4-MD5	Kx=DH	Au=None	Enc=RC4(128)	Mac=MD5
ADH-SEED-SHA	Kx=DH	Au=None	Enc=SEED-CBC(128)	Mac=SHA1
ECDHE-RSA-DES-CBC3-SHA	Kx=ECDH	Au=RSA	Enc=3DES-CBC(168)	Mac=SHA1
ECDHE-RSA-AES128-SHA	Kx=ECDH	Au=RSA	Enc=AES-CBC(128)	Mac=SHA1
ECDHE-RSA-AES256-SHA	Kx=ECDH	Au=RSA	Enc=AES-CBC(256)	Mac=SHA1
ECDHE-RSA-RC4-SHA	Kx=ECDH	Au=RSA	Enc=RC4(128)	Mac=SHA1
AECDH-DES-CBC3-SHA	Kx=ECDH	Au=None	Enc=3DES-CBC(168)	Mac=SHA1
AECDH-AES128-SHA	Kx=ECDH	Au=None	Enc=AES-CBC(128)	Mac=SHA1
AECDH-AES256-SHA	Kx=ECDH	Au=None	Enc=AES-CBC(256)	Mac=SHA1
AECDH-RC4-SHA	Kx=ECDH	Au=None	Enc=RC4(128)	Mac=SHA1
DES-CBC3-SHA	Kx=RSA	Au=RSA	Enc=3DES-CBC(168)	Mac=SHA1
AES128-SHA	Kx=RSA	Au=RSA	Enc=AES-CBC(128)	Mac=SHA1
AES256-SHA	Kx=RSA	Au=RSA	Enc=AES-CBC(256)	Mac=SHA1
CAMELLIA128-SHA	Kx=RSA	Au=RSA	Enc=Camellia-CBC(128)	Mac=SHA1
CAMELLIA256-SHA	Kx=RSA	Au=RSA	Enc=Camellia-CBC(256)	Mac=SHA1
RC4-MD5	Kx=RSA	Au=RSA	Enc=RC4(128)	Mac=MD5
RC4-SHA	Kx=RSA	Au=RSA	Enc=RC4(128)	Mac=SHA1
SEED-SHA	Kx=RSA	Au=RSA	Enc=SEED-CBC(128)	Mac=SHA1
n/a	Kx=ECDHE	Au=RSA	Enc=AES-CBC(128)	Mac=SHA256
n/a	Kx=ECDHE	Au=RSA	Enc=AES-CBC(256)	Mac=SHA384

The fields above are :

{OpenSSL ciphername}

Kx={key exchange}

			Au={authentication} Enc={symmetric encryption method} Mac={message authentication code} {export flag}
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 57041 Synopsis : The remote service supports the use of SSL Perfect Forward Secrecy ciphers, which maintain confidentiality even if the key is stolen. Description : The remote host supports the use of SSL ciphers that offer Perfect Forward Secrecy (PFS) encryption. These cipher suites ensure that recorded SSL traffic cannot be broken at a future date if the server's private key is compromised. See also : http://www.openssl.org/docs/apps/ciphers.html http://en.wikipedia.org/wiki/Diffie-Hellman_key_exchange http://en.wikipedia.org/wiki/Perfect_forward_secrecy Solution : n/a Plugin output : Here is the list of SSL PFS ciphers supported by the remote server : Low Strength Ciphers (< 56-bit key) SSLv3 EXP-EDH-RSA-DES-CBC-SHA Kx=DH(512) Au=RSA Enc=DES-CBC(40) Mac=SHA1 export TLSv1 EXP-EDH-RSA-DES-CBC-SHA Kx=DH(512) Au=RSA Enc=DES-CBC(40) Mac=SHA1 export Medium Strength Ciphers (>= 56-bit and < 112-bit key) SSLv3 EDH-RSA-DES-CBC-SHA Kx=DH Au=RSA Enc=DES-CBC(56) Mac=SHA1 TLSv1 EDH-RSA-DES-CBC-SHA Kx=DH Au=RSA Enc=DES-CBC(56) Mac=SHA1 High Strength Ciphers (>= 112-bit key)

			SSLv3 EDH-RSA-DES-CBC3-SHA Kx=DH Au=RSA Enc=3DES(168) Mac=SHA1 TLSv1 EDH-RSA-DES-CBC3-SHA Kx=DH Au=RSA Enc=3DES-CBC(168) Mac=SHA1 DHE-RSA-AES128-SHA Kx=DH Au=RSA Enc=AES-CBC(128) Mac=SHA1 DHE-RSA-AES256-SHA Kx=DH Au=RSA Enc=AES-CBC(256) Mac=SHA1 DHE-RSA-CAMELLIA128-SHA Kx=DH Au=RSA Enc=Camellia-CBC(128) Mac=SHA1 DHE-RSA-CAMELLIA256-SHA Kx=DH Au=RSA Enc=Camellia-CBC(256) Mac=SHA1 DHE-RSA-SEED-SHA Kx=DH Au=RSA Enc=SEED-CBC(128) Mac=SHA1 ECDHE-RSA-DES-CBC3-SHA Kx=ECDH Au=RSA Enc=3DES-CBC(168) Mac=SHA1 ECDHE-RSA-AES128-SHA Kx=ECDH Au=RSA Enc=AES-CBC(128) Mac=SHA1 ECDHE-RSA-AES256-SHA Kx=ECDH Au=RSA Enc=AES-CBC(256) Mac=SHA1 ECDHE-RSA-RC4-SHA Kx=ECDH Au=RSA Enc=RC4(128) Mac=SHA1 n/a Kx=ECDHE Au=RSA Enc=AES-CBC(128) Mac=SHA256 n/a Kx=ECDHE Au=RSA Enc=AES-CBC(256) Mac=SHA384 The fields above are : {OpenSSL ciphername} Kx={key exchange} Au={authentication} Enc={symmetric encryption method} Mac={message authentication code} {export flag}
75.126.159.2	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 51891 Synopsis : The remote host allows resuming SSL sessions. Description : This script detects whether a host allows resuming SSL sessions by performing a full SSL handshake to receive a session ID, and then reconnecting with the previously used session ID. If the server accepts the session ID in the second connection, the server maintains a cache of sessions that can be resumed. Solution : n/a Plugin output :

			This port supports resuming SSLv3 sessions.
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 14772 Synopsis : This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to identify common services which might have been missed because of a network problem. Solution : See below Plugin output : A web server is running on this port
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 11032 Synopsis : It is possible to enumerate directories on the web server. Description : This plugin attempts to determine the presence of various common directories on the remote web server. By sending a request for a directory, the web server response code indicates if it is a valid directory or not. See also : http://projects.webappsec.org/Predictable-Resource-Location Solution : n/a Plugin output : The following directories were discovered: /cgi-bin, /test, /icons, /info, /mail, /manual, /search While this is not, in and of itself, a bug, you should manually inspect these directories to ensure that they are in compliance with company

			security standards Other references : OWASP:OWASP-CM-006
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 10662 Synopsis : Nessus crawled the remote web site. Description : This script makes a mirror of the remote web site(s) and extracts the list of CGIs that are used by the remote host. It is suggested that you change the number of pages to mirror in the 'Options' section of the client. Solution : n/a Plugin output : Webmirror performed 100 queries in 18s (5.555 queries per second) Directory index found at /search/ Directory index found at /search/select_string/ Extraneous phpinfo() script found at /info Extraneous phpinfo() script found at /test
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 10107 Synopsis : A web server is running on the remote host. Description : This plugin attempts to determine the type and the version of the remote web server. Solution : n/a Plugin output : The remote web server type is :

			Apache and the 'ServerTokens' directive is ProductOnly Apache does not offer a way to hide the server type.
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 24260 Synopsis : Some information about the remote HTTP configuration can be extracted. Description : This test gives some information about the remote HTTP protocol - the version used, whether HTTP Keep-Alive and HTTP pipelining are enabled, etc... This test is informational only and does not denote any security problem. Solution : n/a Plugin output : Protocol version : HTTP/1.1 SSL : no Keep-Alive : no Options allowed : (Not implemented) Headers : Date: Mon, 23 Jun 2014 02:49:24 GMT Server: Apache Vary: Accept-Encoding Content-Length: 0 Connection: close Content-Type: text/html
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 43111 Synopsis : This plugin determines which HTTP methods are allowed on various CGI directories. Description : By calling the OPTIONS method, it is possible to determine which HTTP methods are allowed on each directory. As this list may be incomplete, the plugin also tests - if 'Thorough

tests' are enabled or 'Enable web applications tests' is set to 'yes' in the scan policy - various known HTTP methods on each directory and considers them as unsupported if it receives a response code of 400, 403, 405, or 501.

Note that the plugin output is only informational and does not necessarily indicate the presence of any security vulnerabilities.

Solution :

n/a

Plugin output :

Based on the response to an OPTIONS request :

- HTTP methods GET HEAD OPTIONS POST are allowed on :

/icons
/manual
/manual/de
/manual/en
/manual/en/faq
/manual/en/howto
/manual/en/misc
/manual/en/mod
/manual/en/platform
/manual/en/programs
/manual/en/rewrite
/manual/en/ssl
/manual/en/vhosts
/manual/es
/manual/fr
/manual/images
/search

Based on tests of each method :

- HTTP methods ACL BASELINE-CONTROL BCOPY BDELETE BMOVE BPROPFIND BPROPPATCH CHECKIN CHECKOUT COPY DEBUG DELETE GET HEAD INDEX LABEL LOCK MERGE MKACTIVITY MKCOL MKWORKSPACE MOVE NOTIFY OPTIONS ORDERPATCH PATCH POLL POST PROPFIND PROPPATCH PUT REPORT RPC_IN_DATA RPC_OUT_DATA SEARCH SUBSCRIBE UNCHECKOUT UNLOCK UNSUBSCRIBE UPDATE VERSION-CONTROL X-MS-ENUMATTS are allowed on :

/cgi-bin
/info
/test

- HTTP methods GET HEAD OPTIONS POST are allowed on :

/

			/icons /mail /manual /manual/de /manual/en /manual/en/faq /manual/en/howto /manual/en/misc /manual/en/mod /manual/en/platform /manual/en/programs /manual/en/rewrite /manual/en/ssl /manual/en/vhosts /manual/es /manual/fr /manual/images /search - Invalid/unknown HTTP methods are allowed on : /cgi-bin /info /test
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 48243 Synopsis : It is possible to obtain the version number of the remote PHP install. Description : This plugin attempts to determine the version of PHP available on the remote web server. Solution : n/a Plugin output : Nessus was able to identify the following PHP version information : Version : 5.3.8-2 Source : http://75.126.159.2-static.reverse.softlayer.com/info.php
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 40984 Synopsis :

			Some directories on the remote web server are browsable. Description : Miscellaneous Nessus plugins identified directories on this web server that are browsable. See also : http://www.nessus.org/u?0a35179e Solution : Make sure that browsable directories do not leak confidential informative or give access to sensitive resources. Additionally, use access restrictions or disable directory indexing for any that do. Plugin output : The following directories are browsable : http://75.126.159.2-static.reverse.softlayer.com/search/select_string/ http://75.126.159.2-static.reverse.softlayer.com/search/
75.126.159.2	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 49704 Synopsis : Links to external sites were gathered. Description : Nessus gathered HREF links to external sites by crawling the remote web server. Solution : n/a Plugin output : 53 external URLs were gathered on this web server : URL... - Seen on... http://apache.webthing.com/mod_proxy_html/ - /manual/en/urlmapping.html http://apr.apache.org - /manual/en/install.html http://apr.apache.org/ - /manual/en/glossary.html http://bugs.apache.org/index/full/467 - /manual/en/misc/perf-tuning.html http://cgiwrap.sourceforge.net/ - /manual/en/misc/security_tips.html http://dir.yahoo.com/Computers_and_Internet/Software/Internet/World_Wide_Web/Servers/Log_Analy

			sis_Tools/ - /manual/en/logs.html http://dmoz.org/Computers/Software/Internet/Site_Management/Log_analysis/ - /manual/en/logs.html http://en.wikipedia.org/wiki/PCRE - /manual/en/glossary.html http://hoohoo.ncsa.uiuc.edu/cgi/overview.html - /manual/en/glossary.html http://httpd.apache.org/ - /manual/en/index.html http://httpd.apache.org/dev/verification.html - /manual/en/install.html http://httpd.apache.org/docs-project/ - /manual/en/index.html http://httpd.apache.org/docs/ - /manual/en/index.html http://httpd.apache.org/docs/2.0/upgrading.html - /manual/en/upgrading.html http://httpd.apache.org/docs/2.2/ - /manual/en/install.html http://httpd.apache.org/docs/2.2/suexec.html - /manual/en/suexec.html http://httpd.apache.org/download.cgi - /manual/en/install.html http://httpd.apache.org/download.cgi#verify - /manual/en/install.html http://httpd.apache.org/lists.html#http-announce - /manual/en/misc/security_tips.html http://httpd.apache.org/userslist.html - /manual/en/platform/windows.html http://ietf.org/rfc/rfc2616.txt - /manual/en/glossary.html http://jakarta.apache.org/tomcat/ - /manual/en/new_features_2_2.html http://modules.apache.org/ - /manual/en/filter.html http://online.securityfocus.com/bid/4876/info/ - /manual/en/misc/security_tips.html http://support.microsoft.com/kb/292539/ - /manual/en/platform/windows.html http://wiki.apache.org/httpd/FAQ - /manual/en/index.html http://wiki.apache.org/httpd/Rewrite - /manual/en/rewrite/index.html http://www.apache.org/ - /manual/en/index.html http://www.apache.org/licenses/ - /manual/en/license.html http://www.apache.org/licenses/LICENSE-2.0 - /manual/en/index.html http://www.boutell.com/cgi/ - /manual/en/howto/cgi.html http://www.cpan.org/ - /manual/en/howto/cgi.html http://www.cronolog.org/ - /manual/en/logs.html http://www.gnu.org/ - /manual/en/install.html http://www.gnu.org/software/gcc/gcc.html - /manual/en/install.html http://www.hardened-php.net/ - /info http://www.hpl.hp.com/techreports/Compaq-DEC/WRL-95-4.html - /manual/en/misc/perf-tuning.html http://www.hwg.org/lists/hwg-servers/ - /manual/en/howto/cgi.html http://www.ics.uci.edu/pub/ietf/http/draft-ietf-http-connection-00.txt - /manual/en/misc/perf-tuning.html http://www.ietf.org/rfc/rfc2396.txt - /manual/en/glossary.html http://www.ietf.org/rfc/rfc2817.txt - /manual/en/new_features_2_2.html http://www.ietf.org/rfc/rfc3546.txt - /manual/en/glossary.html http://www.ietf.org/rfc/rfc3875 - /manual/en/howto/cgi.html http://www.ntp.org - /manual/en/install.html http://www.openssl.org/ - /manual/en/glossary.html http://www.pcre.org/ - /manual/en/glossary.html http://www.perl.org/ - /manual/en/install.html http://www.sektioneins.de/ - /info http://www.serverwatch.com/tutorials/article.php/1132731 - /manual/en/env.html http://www.w3.org/CGI/ - /manual/en/glossary.html http://www.w3.org/Protocols/HTTP/Performance/Pipeline.html - /manual/en/misc/perf-tuning.html http://www.w3.org/Protocols/rfc2616/rfc2616.txt - /manual/en/logs.html http://www.webdav.org/ - /manual/en/mod/index.html
75.126.159.2	Low	Pass	Application: general Port: 0 Protocol: udp VATID: 10287 Synopsis :

			It was possible to obtain traceroute information. Description : Makes a traceroute to the remote host. Solution : n/a Plugin output : For your information, here is the traceroute from 38.123.140.114 to 75.126.159.2 : <pre> 38.123.140.114 38.123.140.1 38.122.22.61 154.24.24.1 154.54.85.149 154.54.42.101 154.54.5.233 4.68.63.173 4.53.116.66 173.192.18.153 173.192.18.134 173.192.18.255 66.228.118.178 75.126.159.2 </pre>
75.126.159.2	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 10180 Synopsis : It was possible to identify the status of the remote host (alive or dead) Description : This plugin attempts to determine if the remote host is alive using one or more ping types : - An ARP ping, provided the host is on the local subnet and Nessus is running over ethernet. - An ICMP ping. - A TCP ping, in which the plugin sends to the remote host a packet with the flag SYN, and the host will reply with a RST or a SYN/ACK. - A UDP ping (DNS, RPC, NTP, etc). Solution :

			n/a Plugin output : The remote host is up The remote host replied to an ICMP echo packet
75.126.159.2	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 12053 Synopsis : It was possible to resolve the name of the remote host. Description : Nessus was able to resolve the FQDN of the remote host. Solution : n/a Plugin output : 75.126.159.2 resolves as 75.126.159.2-static.reverse.softlayer.com.
75.126.159.2	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 50350 Synopsis : It was not possible to determine the remote operating system. Description : Using a combination of remote probes (TCP/IP, SMB, HTTP, NTP, SNMP, etc), it was possible to gather one or more fingerprints from the remote system. Unfortunately, though, Nessus does not currently know how to use them to identify the overall system. Solution : n/a Plugin output : If you think these signatures would help us improve OS fingerprinting, please send them to : os-signatures@nessus.org Be sure to include a brief description of the device itself, such as

			the actual operating system or product / model names. HTTP://Server: Apache SMTP://220 mail.srvswbnet ESMTP Postfix (Debian/GNU) SSLcert://CN:srvswbnets/CN:srvswbnet eb05fdce09ef2c1bcc124ed3e94931f241da7856
75.126.159.2	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 14772 Synopsis : This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to identify common services which might have been missed because of a network problem. Solution : See below Plugin output : An FTP server is running on this port
75.126.159.2	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 10092 Synopsis : An FTP server is listening on this port. Description : It is possible to obtain the banner of the remote FTP server by connecting to the remote port. Solution : n/a Plugin output : The remote FTP banner is : 220 (vsFTPD 3.0.2)
75.126.159.2	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 52703

			Synopsis : An FTP server is listening on the remote port. Description : The remote host is running vsftpd, an FTP server for UNIX-like systems written in C. See also : http://vsftpd.beasts.org/ Solution : n/a Plugin output : Source : 220 (vsFTPD 3.0.2) Version : 3.0.2
75.126.159.2	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 39519 Synopsis : Security patches are backported. Description : Security patches may have been 'backported' to the remote FTP server without changing its version number. Banner-based checks have been disabled to avoid false positives. Note that this test is informational only and does not denote any security problem. See also : http://www.nessus.org/u?d636c8c7 Solution : n/a Plugin output : Give Nessus credentials to perform local checks.

75.126.159.3 (75.126.159.3-static.reverse.softlayer.com)			
IP Address	Severity Level	Compliance Status	Details
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28%32%30%33%29%3C%2F%73%63%72%69%70%74%3E ----- output ----- <pre><tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="user" value=" " <script>alert(203)</script>" size=20 ></td> </tr> <tr class='ui_form_pair'></pre>

			----- Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28%32%30%33%29%3C%2F%73%63%72%69%70%74%3E ----- output ----- <pre><tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="user" value=" " <script>alert(203)</script>" size=20 ></td> </tr></pre>

			<tr class='ui_form_pair'> ----- Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28%32%30%33%29%3C%2F%73%63%72%69%70%74%3E ----- output ----- <tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="use r" value=" <script>alert(203)</script>" size=20 ></td>

			</tr> <tr class='ui_form_pair'> ----- Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28%32%30%33%29%3C%2F%73%63%72%69%70%74%3E ----- output ----- <tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="use

			<pre> r" value=" <script>alert(203)</script>" size=20 ></td> </tr> <tr class='ui_form_pair'> ----- Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84 </pre>
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28%32%30%33%29%3C%2F%73%63%72%69%70%74%3E ----- output ----- <pre> <tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> </pre>

			<pre><td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="use r" value=" <script>alert(203)</script>" size=20 ></td> </tr> <tr class='ui_form_pair'> ----- Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84</pre>
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28%32%30%33%29%3C%2F%73%63%72%69%70%74%3E ----- output ----- <pre><tr class='ui_form_pair'></pre>

			<pre> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="use r" value=" <script>alert(203)</script>" size=20 ></td> </tr> <tr class='ui_form_pair'> ----- Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84 </pre>
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28%32%30%33%29%3C%2F%73%63%72%69%70%74%3E ----- output -----

			<pre> <tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="use r" value=" <script>alert(203)</script>" size=20 ></td> </tr> <tr class='ui_form_pair'> ----- Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84 </pre>
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28%32%30%33%29%3C%2F%73%63%72%69%70%74%3E

			<pre> ----- output ----- <tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="use r" value=" <script>alert(203)</script>" size=20 ></td> </tr> <tr class='ui_form_pair'> ----- </pre> Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28%32%30%33%29%3C%2F%73%63%72%69%70%74%3E

			<pre> ----- output ----- <tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="use r" value=" <script>alert(203)</script>" size=20 ></td> </tr> <tr class='ui_form_pair'> ----- </pre> Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28

			%32%30%33%29%3C%2F%73%63%72%69%70%74%3E ----- output ----- <pre> <tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="use r" value=" <script>alert(203)</script>" size=20 ></td> </tr> <tr class='ui_form_pair'> </pre> ----- Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84
75.126.159.3	Medium	Fail	Application: ndmp Port: 10000 Protocol: tcp VATID: 47831 Synopsis : The remote web server is prone to cross-site scripting attacks. Description : The remote web server hosts CGI scripts that fail to adequately sanitize request strings of malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site. These XSS are likely to be 'non-persistent' or 'reflected'. See also : http://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent http://www.nessus.org/u?9717ad85 http://projects.webappsec.org/Cross-Site+Scripting Solution : Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade. CVSS Base Score : 4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N) Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to cross-site scripting (comprehensive test) : + The 'user' parameter of the /session_login.cgi CGI :

			/session_login.cgi?user=%FF%FE%3C%73%63%72%69%70%74%3E%61%6C%65%72%74%28%32%30%33%29%3C%2F%73%63%72%69%70%74%3E ----- output ----- <pre> <tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="use r" value=" <script>alert(203)</script>" size=20 ></td> </tr> <tr class='ui_form_pair'> </pre> Other references : CWE:79, CWE:80, CWE:81, CWE:83, CWE:20, CWE:74, CWE:442, CWE:712, CWE:722, CWE:725, CWE:811, CWE:751, CWE:801, CWE:116, CWE:692, CWE:87, CWE:85, CWE:86, CWE:84
75.126.159.3	Low	Pass	Application: ndmp Port: 10000 Protocol: tcp VATID: 26194 Synopsis : The remote web server might transmit credentials in cleartext. Description : The remote web server contains several HTML form fields containing an input of type 'password' which transmit their information to a remote web server in cleartext. An attacker eavesdropping the traffic between web browser and server may obtain logins and passwords of valid users. Solution : Make sure that every sensitive form transmits content over HTTPS. CVSS Base Score : 2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N) Plugin output : Page : / Destination Page: /session_login.cgi Page : /unauthenticated Destination Page: /session_login.cgi Page : /session_login.cgi Destination Page: /session_login.cgi Other references : CWE:522, CWE:523, CWE:718, CWE:724
75.126.159.3	Low	Pass	Application: http Port: 80

Protocol: tcp
VATID: 26194
Synopsis :

The remote web server might transmit credentials in cleartext.

Description :

The remote web server contains several HTML form fields containing an input of type 'password' which transmit their information to a remote web server in cleartext.

An attacker eavesdropping the traffic between web browser and server may obtain logins and passwords of valid users.

Solution :

Make sure that every sensitive form transmits content over HTTPS.

CVSS Base Score : 2.6
(CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

Plugin output :

Page : /bugzilla/
Destination Page: /bugzilla/index.cgi

Page : /bugzilla/search_plugin.cgi
Destination Page: /bugzilla/search_plugin.cgi

Page : /bugzilla/enter_bug.cgi
Destination Page: /bugzilla/enter_bug.cgi

Page : /bugzilla/describecomponents.cgi
Destination Page: /bugzilla/describecomponents.cgi

Page : /bugzilla/query.cgi
Destination Page: /bugzilla/query.cgi

Page : /bugzilla/buglist.cgi
Destination Page: /bugzilla/buglist.cgi

Page : /bugzilla/createaccount.cgi
Destination Page: /bugzilla/createaccount.cgi

Page : /bugzilla/page.cgi?id=quicksearch.html
Destination Page: /bugzilla/page.cgi

Page : /bugzilla/report.cgi
Destination Page: /bugzilla/report.cgi

Page : /bugzilla/token.cgi
Destination Page: /bugzilla/index.cgi

			Page : /bugzilla/index.cgi Destination Page: /bugzilla/index.cgi Page : /bugzilla/index.cgi?GoAheadAndLogIn=1 Destination Page: /bugzilla/index.cgi Page : /bugzilla/page.cgi?id=release-notes.html Destination Page: /bugzilla/page.cgi Page : /bugzilla/createaccount.cgi?GoAheadAndLogIn=1 Destination Page: /bugzilla/createaccount.cgi Page : /bugzilla/page.cgi Destination Page: /bugzilla/page.cgi Other references : CWE:522, CWE:523, CWE:718, CWE:724
75.126.159.3	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 34324 Synopsis : Authentication credentials might be intercepted. Description : The remote FTP server allows the user's name and password to be transmitted in clear text, which could be intercepted by a network sniffer or a man-in-the-middle attack. Solution : Switch to SFTP (part of the SSH suite) or FTPS (FTP over SSL/TLS). In the latter case, configure the server so that control connections are encrypted. CVSS Base Score : 2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N) Plugin output : This FTP server does not support 'AUTH TLS'. Other references : CWE:522, CWE:523
75.126.159.3	Low	Pass	Application: unknown Port: 55427 Protocol: udp VATID: 11111 Synopsis : An ONC RPC service is running on the remote host.

			Description : By sending a DUMP request to the portmapper, it was possible to enumerate the ONC RPC services running on the remote port. Using this information, it is possible to connect and bind to each service by sending an RPC request to the remote port. Solution : n/a Plugin output : The following RPC services are available on UDP port 55427 : - program: 100024 (status), version: 1
75.126.159.3	Low	Pass	Application: ndmp Port: 10000 Protocol: tcp VATID: 10757 Synopsis : An administration service is running on the remote host. Description : The remote server is running Webmin, a web-based interface for system administration for Unix. See also : http://www.webmin.net/ Solution : Stop the Webmin service if not needed or ensure access is limited to authorized hosts. See the menu items '[Webmin Configuration][IP Access Control]' and/or '[Webmin Configuration][Port and Address]'.
75.126.159.3	Low	Pass	Application: ndmp Port: 10000 Protocol: tcp VATID: 10662 Synopsis : Nessus crawled the remote web site. Description : This script makes a mirror of the remote web site(s) and extracts the list of CGIs that are used by the remote host. It is suggested that you change the number of pages to mirror in the 'Options' section of the client.

			Solution : n/a Plugin output : Webmirror performed 5 queries in 2s (2.500 queries per second) The following CGI have been discovered: + CGI: /session_login.cgi Methods: POST Argument: page Value: / Argument: pass Argument: save Value: 1 Argument: user
75.126.159.3	Low	Pass	Application: ndmp Port: 10000 Protocol: tcp VATID: 10107 Synopsis : A web server is running on the remote host. Description : This plugin attempts to determine the type and the version of the remote web server. Solution : n/a Plugin output : The remote web server type is : MiniServ/1.620
75.126.159.3	Low	Pass	Application: ndmp Port: 10000 Protocol: tcp VATID: 43111 Synopsis : This plugin determines which HTTP methods are allowed on various CGI directories. Description :

			By calling the OPTIONS method, it is possible to determine which HTTP methods are allowed on each directory. As this list may be incomplete, the plugin also tests - if 'Thorough tests' are enabled or 'Enable web applications tests' is set to 'yes' in the scan policy - various known HTTP methods on each directory and considers them as unsupported if it receives a response code of 400, 403, 405, or 501. Note that the plugin output is only informational and does not necessarily indicate the presence of any security vulnerabilities. Solution : n/a Plugin output : Based on tests of each method : - HTTP methods ACL BASELINE-CONTROL BCOPY BDELETE BMOVE BPROPFIND BPROPPATCH CHECKIN CHECKOUT COPY DEBUG DELETE GET HEAD INDEX LABEL LOCK MERGE MKACTIVITY MKCOL MKWORKSPACE MOVE NOTIFY OPTIONS ORDERPATCH PATCH POLL POST PROPFIND PROPPATCH REPORT RPC_IN_DATA RPC_OUT_DATA SUBSCRIBE TRACE UNCHECKOUT UNLOCK UNSUBSCRIBE UPDATE VERSION-CONTROL X-MS-ENUMATTS are allowed on : / /unauthenticated - Invalid/unknown HTTP methods are allowed on : / /unauthenticated
75.126.159.3	Low	Pass	Application: ndmp Port: 10000 Protocol: tcp VATID: 47830 Synopsis : Some CGIs are candidate for extended injection tests. Description : Nessus was able to inject innocuous strings into CGI parameters and read them back in the HTTP response. The affected parameters are candidates for extended injection tests like cross-site scripting attacks. This is not a weakness per se, the main purpose of this test is to speed up other scripts. The results may be useful for a human pen-tester.

			Solution : n/a Plugin output : Using the POST HTTP method, Nessus found that : + The following resources may be vulnerable to injectable parameter : + The 'user' parameter of the /session_login.cgi CGI : /session_login.cgi [user=%00eqiooo] ----- output ----- <pre><tr class='ui_form_pair'> <td class='ui_form_label' >Username</td> <td class='ui_form_value' colspan=1 ><input class='ui_textbox' name="use r" value=".eqiooo" size=20 ></td> </tr> <tr class='ui_form_pair'> </pre> ----- Other references : CWE:86
75.126.159.3	Low	Pass	Application: ndmp Port: 10000 Protocol: tcp VATID: 40773 Synopsis : An application was found that may use CGI parameters to control sensitive information. Description : According to their names, some CGI parameters may control sensitive data (e.g., ID, privileges, commands, prices, credit card data, etc.). In the course of using an application, these variables may disclose sensitive data or be prone to tampering that could result in privilege escalation. These parameters should be examined to determine what type of data is controlled and if it poses a security risk. ** This plugin only reports information that may be useful for auditors ** or pen-testers, not a real flaw. Solution : Ensure sensitive data is not disclosed by CGI parameters. In addition, do not use CGI parameters to control access to resources or privileges. Plugin output :

			Potentially sensitive parameters for CGI /session_login.cgi : user : Potential horizontal privilege escalation - try another user ID pass : Possibly a clear or hashed password, vulnerable to sniffing or dictionary attack																																																																																																																		
75.126.159.3	Low	Pass	Application: ndmp Port: 10000 Protocol: tcp VATID: 33817 Synopsis : Load estimation for web application tests. Description : This script computes the maximum number of requests that would be done by the generic web tests, depending on miscellaneous options. It does not perform any test by itself. The results can be used to estimate the duration of these tests, or the complexity of additional manual tests. Note that the script does not try to compute this duration based on external factors such as the network and web servers loads. Solution : n/a Plugin output : Here are the estimated number of requests in miscellaneous modes for one method only (GET or POST) : [Single / Some Pairs / All Pairs / Some Combinations / All Combinations] <table><tr><td>arbitrary command execution (time based) :</td><td>S=24</td><td>SP=60</td><td>AP=60</td><td>SC=72</td><td>AC=72</td></tr><tr><td>injectable parameter</td><td>: S=8</td><td>SP=20</td><td>AP=20</td><td>SC=24</td><td>AC=24</td></tr><tr><td>unseen parameters</td><td>: S=140</td><td>SP=350</td><td>AP=350</td><td>SC=420</td><td>AC=420</td></tr><tr><td>XML injection</td><td>: S=4</td><td>SP=10</td><td>AP=10</td><td>SC=12</td><td>AC=12</td></tr><tr><td>SQL injection (2nd order)</td><td>: S=4</td><td>SP=10</td><td>AP=10</td><td>SC=12</td><td>AC=12</td></tr><tr><td>blind SQL injection</td><td>: S=120</td><td>SP=300</td><td>AP=300</td><td>SC=360</td><td>AC=360</td></tr><tr><td>SQL injection</td><td>: S=112</td><td>SP=280</td><td>AP=280</td><td>SC=336</td><td>AC=336</td></tr><tr><td>SSI injection</td><td>: S=12</td><td>SP=30</td><td>AP=30</td><td>SC=36</td><td>AC=36</td></tr><tr><td>cross-site scripting (comprehensive test):</td><td>S=16</td><td>SP=40</td><td>AP=40</td><td>SC=48</td><td>AC=48</td></tr><tr><td>local file inclusion</td><td>: S=4</td><td>SP=10</td><td>AP=10</td><td>SC=12</td><td>AC=12</td></tr><tr><td>blind SQL injection (4 requests)</td><td>: S=16</td><td>SP=40</td><td>AP=40</td><td>SC=48</td><td>AC=48</td></tr><tr><td>directory traversal</td><td>: S=116</td><td>SP=290</td><td>AP=290</td><td>SC=348</td><td>AC=348</td></tr><tr><td>web code injection</td><td>: S=4</td><td>SP=10</td><td>AP=10</td><td>SC=12</td><td>AC=12</td></tr><tr><td>HTTP response splitting</td><td>: S=9</td><td>SP=9</td><td>AP=9</td><td>SC=9</td><td>AC=9</td></tr><tr><td>directory traversal (extended test)</td><td>: S=204</td><td>SP=510</td><td>AP=510</td><td>SC=612</td><td>AC=612</td></tr><tr><td>script injection</td><td>: S=1</td><td>SP=1</td><td>AP=1</td><td>SC=1</td><td>AC=1</td></tr><tr><td>persistent XSS</td><td>: S=16</td><td>SP=40</td><td>AP=40</td><td>SC=48</td><td>AC=48</td></tr><tr><td>directory traversal (write access)</td><td>: S=8</td><td>SP=20</td><td>AP=20</td><td>SC=24</td><td>AC=24</td></tr><tr><td>header injection</td><td>: S=2</td><td>SP=2</td><td>AP=2</td><td>SC=2</td><td>AC=2</td></tr></table>	arbitrary command execution (time based) :	S=24	SP=60	AP=60	SC=72	AC=72	injectable parameter	: S=8	SP=20	AP=20	SC=24	AC=24	unseen parameters	: S=140	SP=350	AP=350	SC=420	AC=420	XML injection	: S=4	SP=10	AP=10	SC=12	AC=12	SQL injection (2nd order)	: S=4	SP=10	AP=10	SC=12	AC=12	blind SQL injection	: S=120	SP=300	AP=300	SC=360	AC=360	SQL injection	: S=112	SP=280	AP=280	SC=336	AC=336	SSI injection	: S=12	SP=30	AP=30	SC=36	AC=36	cross-site scripting (comprehensive test):	S=16	SP=40	AP=40	SC=48	AC=48	local file inclusion	: S=4	SP=10	AP=10	SC=12	AC=12	blind SQL injection (4 requests)	: S=16	SP=40	AP=40	SC=48	AC=48	directory traversal	: S=116	SP=290	AP=290	SC=348	AC=348	web code injection	: S=4	SP=10	AP=10	SC=12	AC=12	HTTP response splitting	: S=9	SP=9	AP=9	SC=9	AC=9	directory traversal (extended test)	: S=204	SP=510	AP=510	SC=612	AC=612	script injection	: S=1	SP=1	AP=1	SC=1	AC=1	persistent XSS	: S=16	SP=40	AP=40	SC=48	AC=48	directory traversal (write access)	: S=8	SP=20	AP=20	SC=24	AC=24	header injection	: S=2	SP=2	AP=2	SC=2	AC=2
arbitrary command execution (time based) :	S=24	SP=60	AP=60	SC=72	AC=72																																																																																																																
injectable parameter	: S=8	SP=20	AP=20	SC=24	AC=24																																																																																																																
unseen parameters	: S=140	SP=350	AP=350	SC=420	AC=420																																																																																																																
XML injection	: S=4	SP=10	AP=10	SC=12	AC=12																																																																																																																
SQL injection (2nd order)	: S=4	SP=10	AP=10	SC=12	AC=12																																																																																																																
blind SQL injection	: S=120	SP=300	AP=300	SC=360	AC=360																																																																																																																
SQL injection	: S=112	SP=280	AP=280	SC=336	AC=336																																																																																																																
SSI injection	: S=12	SP=30	AP=30	SC=36	AC=36																																																																																																																
cross-site scripting (comprehensive test):	S=16	SP=40	AP=40	SC=48	AC=48																																																																																																																
local file inclusion	: S=4	SP=10	AP=10	SC=12	AC=12																																																																																																																
blind SQL injection (4 requests)	: S=16	SP=40	AP=40	SC=48	AC=48																																																																																																																
directory traversal	: S=116	SP=290	AP=290	SC=348	AC=348																																																																																																																
web code injection	: S=4	SP=10	AP=10	SC=12	AC=12																																																																																																																
HTTP response splitting	: S=9	SP=9	AP=9	SC=9	AC=9																																																																																																																
directory traversal (extended test)	: S=204	SP=510	AP=510	SC=612	AC=612																																																																																																																
script injection	: S=1	SP=1	AP=1	SC=1	AC=1																																																																																																																
persistent XSS	: S=16	SP=40	AP=40	SC=48	AC=48																																																																																																																
directory traversal (write access)	: S=8	SP=20	AP=20	SC=24	AC=24																																																																																																																
header injection	: S=2	SP=2	AP=2	SC=2	AC=2																																																																																																																

			on site request forgery : S=1 SP=1 AP=1 SC=1 AC=1 format string : S=8 SP=20 AP=20 SC=24 AC=24 arbitrary command execution : S=88 SP=220 AP=220 SC=264 AC=264 cross-site scripting (extended patterns) : S=6 SP=6 AP=6 SC=6 AC=6 HTML injection : S=5 SP=5 AP=5 SC=5 AC=5 All tests : S=928 SP=2284 AP=2284 SC=2736 AC=2736 Here are the estimated number of requests in miscellaneous modes for both methods (GET and POST) : [Single / Some Pairs / All Pairs / Some Combinations / All Combinations] arbitrary command execution (time based) : S=48 SP=120 AP=120 SC=144 AC=144 injectable parameter : S=16 SP=40 AP=40 SC=48 AC=48 unseen parameters : S=280 SP=700 AP=700 SC=840 AC=840 XML injection : S=8 SP=20 AP=20 SC=24 AC=24 SQL injection (2nd order) : S=8 SP=20 AP=20 SC=24 AC=24 blind SQL injection : S=240 SP=600 AP=600 SC=720 AC=720 SQL injection : S=224 SP=560 AP=560 SC=672 AC=672 SSI injection : S=24 SP=60 AP=60 SC=72 AC=72 cross-site scripting (comprehensive test): S=32 SP=80 AP=80 SC=96 AC=96 local file inclusion : S=8 SP=20 AP=20 SC=24 AC=24 blind SQL injection (4 requests) : S=32 SP=80 AP=80 SC=96 AC=96 directory traversal : S=232 SP=580 AP=580 SC=696 AC=696 web code injection : S=8 SP=20 AP=20 SC=24 AC=24 HTTP response splitting : S=18 SP=18 AP=18 SC=18 AC=18 directory traversal (extended test) : S=408 SP=1020 AP=1020 SC=1224 AC=1224 script injection : S=2 SP=2 AP=2 SC=2 AC=2 persistent XSS : S=32 SP=80 AP=80 SC=96 AC=96 directory traversal (write access) : S=16 SP=40 AP=40 SC=48 AC=48 header injection : S=4 SP=4 AP=4 SC=4 AC=4 on site request forgery : S=2 SP=2 AP=2 SC=2 AC=2 format string : S=16 SP=40 AP=40 SC=48 AC=48 arbitrary command execution : S=176 SP=440 AP=440 SC=528 AC=528 cross-site scripting (extended patterns) : S=12 SP=12 AP=12 SC=12 AC=12 HTML injection : S=10 SP=10 AP=10 SC=10 AC=10 All tests : S=1856 SP=4568 AP=4568 SC=5472 AC=5472 Your mode : single, GET and POST, experimental tests. Maximum number of requests : 1856
75.126.159.3	Low	Pass	Application: ndmp Port: 10000 Protocol: tcp VATID: 39470 Synopsis : Some generic CGI attacks ran out of time. Description : Some generic CGI tests ran out of time during the scan.

			The results may be incomplete. Solution : Consider increasing the 'maximum run time (min)' preference for the 'Web Application Tests Settings' in order to prevent the CGI scanning from timing out. Less ambitious options could also be used, such as : - Combinations of arguments values = 'all combinations' is much slower than 'two pairs' or 'single'. - Stop at first flaw = 'per port' is quicker. - In 'some pairs' or 'some combinations' mode, try reducing web_app_tests.tested_values_for_each_parameter in nessusd.conf Plugin output : The following tests timed out without finding any flaw : - SQL injection (on HTTP headers) - SQL injection - directory traversal - arbitrary command execution
75.126.159.3	Low	Pass	Application: unknown Port: 33494 Protocol: tcp VATID: 11111 Synopsis : An ONC RPC service is running on the remote host. Description : By sending a DUMP request to the portmapper, it was possible to enumerate the ONC RPC services running on the remote port. Using this information, it is possible to connect and bind to each service by sending an RPC request to the remote port. Solution : n/a Plugin output : The following RPC services are available on TCP port 33494 : - program: 100024 (status), version: 1
75.126.159.3	Low	Pass	Application: mysql Port: 3306 Protocol: tcp VATID: 10719 Synopsis :

			A database server is listening on the remote port. Description : The remote host is running MySQL, an open source database server. Solution : n/a Plugin output : Version : 5.5.33-1 Protocol : 10 Server Status : SERVER_STATUS_AUTOCOMMIT Server Capabilities : CLIENT_LONG_PASSWORD (new more secure passwords) CLIENT_FOUND_ROWS (Found instead of affected rows) CLIENT_LONG_FLAG (Get all column flags) CLIENT_CONNECT_WITH_DB (One can specify db on connect) CLIENT_NO_SCHEMA (Don't allow database.table.column) CLIENT_COMPRESS (Can use compression protocol) CLIENT_ODBC (ODBC client) CLIENT_LOCAL_FILES (Can use LOAD DATA LOCAL) CLIENT_IGNORE_SPACE (Ignore spaces before "(" CLIENT_PROTOCOL_41 (New 4.1 protocol) CLIENT_INTERACTIVE (This is an interactive client) CLIENT_SIGPIPE (IGNORE sigpipes) CLIENT_TRANSACTIONS (Client knows about transactions) CLIENT_RESERVED (Old flag for 4.1 protocol) CLIENT_SECURE_CONNECTION (New 4.1 authentication)
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 14772 Synopsis : This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to identify common services which might have been missed because of a network problem. Solution : See below Plugin output : A web server is running on this port
75.126.159.3	Low	Pass	Application: http

			Port: 80 Protocol: tcp VATID: 11032 Synopsis : It is possible to enumerate directories on the web server. Description : This plugin attempts to determine the presence of various common directories on the remote web server. By sending a request for a directory, the web server response code indicates if it is a valid directory or not. See also : http://projects.webappsec.org/Predictable-Resource-Location Solution : n/a Plugin output : The following directories were discovered: /bugzilla While this is not, in and of itself, a bug, you should manually inspect these directories to ensure that they are in compliance with company security standards Other references : OWASP:OWASP-CM-006
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 10662 Synopsis : Nessus crawled the remote web site. Description : This script makes a mirror of the remote web site(s) and extracts the list of CGIs that are used by the remote host. It is suggested that you change the number of pages to mirror in the 'Options' section of the client. Solution : n/a Plugin output :

Webmirror performed 121 queries in 22s (5.500 queries per second)

The following CGI have been discovered:

+ CGI: /bugzilla/buglist.cgi

Methods: GET,POST

Argument: Bugzilla_login

Argument: Bugzilla_password

Argument: Bugzilla_restrictlogin

Argument: GoAheadAndLogIn

Value: Log in

Argument: no_redirect

Value: 0

Argument: quicksearch

+ CGI: /bugzilla/page.cgi

Methods: GET,POST

Argument: Bugzilla_login

Argument: Bugzilla_password

Argument: Bugzilla_restrictlogin

Argument: GoAheadAndLogIn

Value: Log in

Argument: id

Value: quicksearch.html

Value: release-notes.html

+ CGI: /bugzilla/index.cgi

Methods: GET,POST

Argument: Bugzilla_login

Argument: Bugzilla_password

Argument: Bugzilla_restrictlogin

Argument: GoAheadAndLogIn

Value: 1

Value: Log in

Value: 1#forgot

+ CGI: /bugzilla/token.cgi

Methods: GET,POST

Argument: a

Value: reqpw

Argument: loginname

Argument: token

Value: 1403490799-aCxvMsK5shLF_huFCIMOS9Fmq3_T7aIsX_DJ52-B5KY

Value: 1403490801-eYr5EOjr9ZcsZVCOa8wV7sEy7bwy_FNhzoT4tMc9fg

Value: 1403490803-JYKoZMQr--LcVhb5T0N993GLY8RIUk8HWLwdjeJlK5c

Value: 1403490805-0hijlTH-gLV7-9gO1xdU5iucssBzhl367AuZrtZ3vM4

Value: 1403490806-3HwCAQFdBAIhOzyynnWd1wplvPv-qmVqV9uw04qMfQ

Value: 1403490808-s26zUueCzppwxGGvuuZ8chzEHUgFjV__Qow1-SuITL0

Value: 1403490810-JXqyN7aQz0T1vIa-wpQyXn9uD6L7_U7Z0emN1U2kW34
Value: 1403490813-p_gReb261vOrzYbn4pJDIUaegGRFqFklw4isHLID4Eg

+ CGI: /bugzilla/search_plugin.cgi
Methods: POST
Argument: Bugzilla_login
Argument: Bugzilla_password
Argument: Bugzilla_restrictlogin
Argument: GoAheadAndLogIn
Value: Log in

+ CGI: /bugzilla/enter_bug.cgi
Methods: POST
Argument: Bugzilla_login
Argument: Bugzilla_password
Argument: Bugzilla_restrictlogin
Argument: GoAheadAndLogIn
Value: Log in

+ CGI: /bugzilla/describecomponents.cgi
Methods: POST
Argument: Bugzilla_login
Argument: Bugzilla_password
Argument: Bugzilla_restrictlogin
Argument: GoAheadAndLogIn
Value: Log in

+ CGI: /bugzilla/query.cgi
Methods: POST
Argument: Bugzilla_login
Argument: Bugzilla_password
Argument: Bugzilla_restrictlogin
Argument: GoAheadAndLogIn
Value: Log in

+ CGI: /bugzilla/createaccount.cgi
Methods: GET,POST
Argument: Bugzilla_login
Argument: Bugzilla_password
Argument: Bugzilla_restrictlogin
Argument: GoAheadAndLogIn
Value: 1
Value: Log in
Value: 1#forgot
Argument: login
Argument: token
Value: 1403490803-fZ4ZVHjfaRxIFRzzl7aZ1qzdUn6bSCyOc0T7cUzuLNE
Value: 1403490808-94XmhedSrdoQipld-JuWO__r-eS6ZA6LFcFJoz-z110

			+ CGI: /bugzilla/report.cgi Methods: POST Argument: Bugzilla_login Argument: Bugzilla_password Argument: Bugzilla_restrictlogin Argument: GoAheadAndLogIn Value: Log in + CGI: /bugzilla/docs/page.cgi Methods: GET Argument: id Value: quicksearch.html
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 49705 Synopsis : Email addresses were harvested from the web server. Description : Nessus harvested HREF mailto: links and extracted email addresses by crawling the remote web server. Solution : n/a Plugin output : The following email addresses have been gathered : - 'terry@mozilla.org', referenced from : /bugzilla/docs/en/html/credits.html - 'tara@tequilarists.org', referenced from : /bugzilla/docs/en/html/credits.html - 'mbarnson@sisna.com', referenced from : /bugzilla/docs/en/html/credits.html - 'mamta@linkexplore.com', referenced from : /bugzilla/createaccount.cgi - 'justdave@bugzilla.org', referenced from : /bugzilla/docs/en/html/credits.html - 'jake@bugzilla.org', referenced from :

			/bugzilla/docs/en/html/credits.html - 'endico@mozilla.org', referenced from : /bugzilla/docs/en/html/credits.html - 'dkl@redhat.com', referenced from : /bugzilla/docs/en/html/credits.html
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 42057 Synopsis : Auto-complete is not disabled on password fields. Description : The remote web server contains at least HTML form field containing an input of type 'password' where 'autocomplete' is not set to 'off'. While this does not represent a risk to this web server per se, it does mean that users who use the affected forms may have their credentials saved in their browsers, which could in turn lead to a loss of confidentiality if any of them use a shared host or their machine is compromised at some point. Solution : Add the attribute 'autocomplete=off' to these fields to prevent browsers from caching credentials. Plugin output : Page : /bugzilla/ Destination Page: /bugzilla/index.cgi Page : /bugzilla/search_plugin.cgi Destination Page: /bugzilla/search_plugin.cgi Page : /bugzilla/enter_bug.cgi Destination Page: /bugzilla/enter_bug.cgi Page : /bugzilla/describecomponents.cgi Destination Page: /bugzilla/describecomponents.cgi Page : /bugzilla/query.cgi Destination Page: /bugzilla/query.cgi Page : /bugzilla/buglist.cgi Destination Page: /bugzilla/buglist.cgi Page : /bugzilla/createaccount.cgi Destination Page: /bugzilla/createaccount.cgi

			Page : /bugzilla/page.cgi?id=quicksearch.html Destination Page: /bugzilla/page.cgi Page : /bugzilla/report.cgi Destination Page: /bugzilla/report.cgi Page : /bugzilla/token.cgi Destination Page: /bugzilla/index.cgi Page : /bugzilla/index.cgi Destination Page: /bugzilla/index.cgi Page : /bugzilla/index.cgi?GoAheadAndLogIn=1 Destination Page: /bugzilla/index.cgi Page : /bugzilla/page.cgi?id=release-notes.html Destination Page: /bugzilla/page.cgi Page : /bugzilla/createaccount.cgi?GoAheadAndLogIn=1 Destination Page: /bugzilla/createaccount.cgi Page : /bugzilla/page.cgi Destination Page: /bugzilla/page.cgi
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 49704 Synopsis : Links to external sites were gathered. Description : Nessus gathered HREF links to external sites by crawling the remote web server. Solution : n/a Plugin output : 46 external URLs were gathered on this web server : URL... - Seen on... http://aspn.activestate.com/ASPN/Downloads/ActivePerl/ - /bugzilla/docs/en/html/os-specific.html http://bugzilla.mozilla.org/enter_bug.cgi?product=Bugzilla;component=Documentation - /bugzilla/docs/en/html/conventions.html http://bugzilla.mozilla.org/show_bug.cgi?id=186383 - /bugzilla/docs/en/html/security-webserver.html http://bzr.mozilla.org/bugzilla/ - /bugzilla/docs/en/html/upgrade.html http://httpd.apache.org/ - /bugzilla/docs/en/html/installation.html

			http://httpd.apache.org/docs-2.0/mod/core.html#scriptinterpretersource - /bugzilla/docs/en/html/os-specific.html http://landfill.bugzilla.org/ - /bugzilla/docs/en/html/using-intro.html http://landfill.bugzilla.org/bugzilla-4.4-branch/ - /bugzilla/docs/en/html/myaccount.html http://landfill.bugzilla.org/bugzilla-4.4-branch/page.cgi?id=bug-writing.html - /bugzilla/docs/en/html/bugreports.html http://landfill.bugzilla.org/bugzilla-4.4-branch/query.cgi - /bugzilla/docs/en/html/query.html http://landfill.bugzilla.org/bugzilla-4.4-branch/show_bug.cgi?id=1 - /bugzilla/docs/en/html/bug_page.html http://landfill.bugzilla.org/bugzilla-tip/enter_bug.cgi?product=WorldControl;format=guided - /bugzilla/docs/en/html/cust-templates.html http://online.securityfocus.com/bid/6501 - /bugzilla/docs/en/html/security-webserver.html http://perl.apache.org - /bugzilla/docs/en/html/installation.html http://sourceforge.net/projects/fink/ - /bugzilla/docs/en/html/os-specific.html http://sqlite.org/faq.html#q5 - /bugzilla/docs/en/html/configuration.html http://support.microsoft.com/default.aspx?scid=kb;en-us;231998 - /bugzilla/docs/en/html/configuration.html http://support.microsoft.com/default.aspx?scid=kb;en-us;245225 - /bugzilla/docs/en/html/configuration.html http://wiki.mozilla.org/Bugzilla:FAQ - /bugzilla/docs/en/html/using-intro.html http://www.activestate.com/ - /bugzilla/docs/en/html/os-specific.html http://www.bugzilla.org - /bugzilla/docs/en/html/hintsandtips.html http://www.bugzilla.org/docs/ - /bugzilla/docs/en/html/index.html http://www.bugzilla.org/docs/developer.html - /bugzilla/docs/en/html/cust-templates.html http://www.bugzilla.org/download.html#localizations - /bugzilla/docs/en/html/cust-templates.html http://www.bugzilla.org/download/ - /bugzilla/docs/en/html/installation.html http://www.bugzilla.org/download/#localizations - /bugzilla/docs/en/html/newversions.html http://www.bugzilla.org/releases/ - /bugzilla/docs/en/html/upgrade.html http://www.cert.org/tech_tips/malicious_code_mitigation.html#3 - /bugzilla/docs/en/html/security-bugzilla.html http://www.gnome.org/projects/dia - /bugzilla/docs/en/html/lifecycle.html http://www.macports.org/ - /bugzilla/docs/en/html/os-specific.html http://www.mysql.com - /bugzilla/docs/en/html/installation.html http://www.mysql.com/doc/en/Fulltext_Fine-tuning.html - /bugzilla/docs/en/html/configuration.html http://www.nncron.ru/ - /bugzilla/docs/en/html/extraconfig.html http://www.oracle.com/ - /bugzilla/docs/en/html/installation.html http://www.perl.org - /bugzilla/docs/en/html/installation.html http://www.postfix.org/ - /bugzilla/docs/en/html/os-specific.html http://www.postgresql.org/ - /bugzilla/docs/en/html/installation.html http://www.ravenbrook.com/project/p4dti/tool/cgi/bugzilla-schema/ - /bugzilla/docs/en/html/configuration.html http://www.template-toolkit.org - /bugzilla/docs/en/html/cust-templates.html https://bugzilla.mozilla.org/show_bug.cgi?id=201069 - /bugzilla/docs/en/html/parameters.html https://wiki.mozilla.org/Bugzilla:Addons - /bugzilla/docs/en/html/integration.html https://wiki.mozilla.org/Bugzilla:Bzr - /bugzilla/docs/en/html/installation.html https://wiki.mozilla.org/Bugzilla:L10n - /bugzilla/docs/en/html/newversions.html https://wiki.mozilla.org/Bugzilla:Moving_From_CVS_To_Bazaar - /bugzilla/docs/en/html/upgrade.html https://wiki.mozilla.org/Bugzilla:Prerequisites - /bugzilla/docs/en/html/os-specific.html https://wiki.mozilla.org/Bugzilla:Win32Install - /bugzilla/docs/en/html/os-specific.html
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 10107

			Synopsis : A web server is running on the remote host. Description : This plugin attempts to determine the type and the version of the remote web server. Solution : n/a Plugin output : The remote web server type is : Apache and the 'ServerTokens' directive is ProductOnly Apache does not offer a way to hide the server type.
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 43111 Synopsis : This plugin determines which HTTP methods are allowed on various CGI directories. Description : By calling the OPTIONS method, it is possible to determine which HTTP methods are allowed on each directory. As this list may be incomplete, the plugin also tests - if 'Thorough tests' are enabled or 'Enable web applications tests' is set to 'yes' in the scan policy - various known HTTP methods on each directory and considers them as unsupported if it receives a response code of 400, 403, 405, or 501. Note that the plugin output is only informational and does not necessarily indicate the presence of any security vulnerabilities. Solution : n/a Plugin output : Based on the response to an OPTIONS request : - HTTP methods GET HEAD OPTIONS POST are allowed on :

			/ /bugzilla/docs /bugzilla/docs/en /bugzilla/docs/en/html /bugzilla/images /bugzilla/skins /bugzilla/skins/contrib /bugzilla/skins/contrib/Dusk /bugzilla/skins/standard Based on tests of each method : - HTTP methods GET HEAD OPTIONS POST are allowed on : / /bugzilla /bugzilla/docs /bugzilla/docs/en /bugzilla/docs/en/html /bugzilla/images /bugzilla/skins /bugzilla/skins/contrib /bugzilla/skins/contrib/Dusk /bugzilla/skins/standard
75.126.159.3	Low	Pass	Application: sunrpc Port: 111 Protocol: udp VATID: 10223 Synopsis : An ONC RPC portmapper is running on the remote host. Description : The RPC portmapper is running on this port. The portmapper allows someone to get the port number of each RPC service running on the remote host by sending either multiple lookup requests or a DUMP request. Solution : n/a CVE : CVE-1999-0632
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 24260 Synopsis : Some information about the remote HTTP configuration can be extracted.

			Description : This test gives some information about the remote HTTP protocol - the version used, whether HTTP Keep-Alive and HTTP pipelining are enabled, etc... This test is informational only and does not denote any security problem. Solution : n/a Plugin output : Protocol version : HTTP/1.1 SSL : no Keep-Alive : yes Options allowed : (Not implemented) Headers : Date: Mon, 23 Jun 2014 02:34:19 GMT Server: Apache Last-Modified: Mon, 09 Apr 2012 08:32:22 GMT ETag: "5d62b3-b1-4bd3ad8545180" Accept-Ranges: bytes Content-Length: 177 Keep-Alive: timeout=15, max=100 Connection: Keep-Alive Content-Type: text/html
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 11462 Synopsis : A bug tracker is running on the remote host. Description : The remote web server is hosting Bugzilla, a web application for bug tracking and managing software development. See also : http://www.bugzilla.org/ Solution : n/a Plugin output :

			The following instance of Bugzilla was detected on the remote host : Version : 4.4.2 URL : http://75.126.159.3-static.reverse.softlayer.com/bugzilla/query.cgi
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 47830 Synopsis : Some CGIs are candidate for extended injection tests. Description : Nessus was able to inject innocuous strings into CGI parameters and read them back in the HTTP response. The affected parameters are candidates for extended injection tests like cross-site scripting attacks. This is not a weakness per se, the main purpose of this test is to speed up other scripts. The results may be useful for a human pen-tester. Solution : n/a Plugin output : Using the GET HTTP method, Nessus found that : + The following resources may be vulnerable to injectable parameter : + The 'a' parameter of the /bugzilla/token.cgi CGI : /bugzilla/token.cgi?a=reqpw&a=%00eqiooo ----- output ----- value="reqpw"> <input type="hidden" name="a" value=".eqiooo"> <input type="hidden" name="token" value="1403490903-x6IMn8Ji0imMJu [...]" <input type="submit" id="confirm" value="Yes, Confirm Changes"> ----- + The 'GoAheadAndLogIn' parameter of the /bugzilla/index.cgi CGI : /bugzilla/index.cgi?GoAheadAndLogIn=%00eqiooo ----- output ----- </table> <input type="hidden" name="GoAheadAndLogIn"

```

value=".eqiooo">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">
-----

+ The 'GoAheadAndLogIn' parameter of the /bugzilla/search_plugin.cgi CGI :

/bugzilla/search_plugin.cgi?GoAheadAndLogIn=%00eqiooo

----- output -----
</table>
<input type="hidden" name="GoAheadAndLogIn"
value=".eqiooo">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">
-----

+ The 'GoAheadAndLogIn' parameter of the /bugzilla/enter_bug.cgi CGI :

/bugzilla/enter_bug.cgi?GoAheadAndLogIn=%00eqiooo

----- output -----
</table>
<input type="hidden" name="GoAheadAndLogIn"
value=".eqiooo">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">
-----

+ The 'GoAheadAndLogIn' parameter of the /bugzilla/describecomponents.cgi CGI :

/bugzilla/describecomponents.cgi?GoAheadAndLogIn=%00eqiooo

----- output -----
</table>
<input type="hidden" name="GoAheadAndLogIn"
value=".eqiooo">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">
-----

+ The 'GoAheadAndLogIn' parameter of the /bugzilla/query.cgi CGI :

/bugzilla/query.cgi?GoAheadAndLogIn=%00eqiooo

----- output -----
</table>
<input type="hidden" name="GoAheadAndLogIn"
value=".eqiooo">

<input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in">
-----

```

			+ The 'GoAheadAndLogIn' parameter of the /bugzilla/report.cgi CGI : <pre>/bugzilla/report.cgi?GoAheadAndLogIn=%00eqiooo</pre> ----- output ----- <pre></table> <input type="hidden" name="GoAheadAndLogIn" value=".eqiooo"> <input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in"> -----</pre> + The 'id' parameter of the /bugzilla/page.cgi CGI : <pre>/bugzilla/page.cgi?id=%00eqiooo</pre> ----- output ----- <pre></table> <input type="hidden" name="id" value=".eqiooo"> <input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in"> -----</pre> + The 'quicksearch' parameter of the /bugzilla/buglist.cgi CGI : <pre>/bugzilla/buglist.cgi?quicksearch=%00eqiooo</pre> ----- output ----- <pre></table> <input type="hidden" name="quicksearch" value=".eqiooo"> <input type="submit" name="GoAheadAndLogIn" value="Log in" id="log_in"> -----</pre> + The 'token' parameter of the /bugzilla/createaccount.cgi CGI : <pre>/bugzilla/createaccount.cgi?token=%00eqiooo</pre> ----- output ----- <pre><li id="mini_login_container_top"> </pre>
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 40773 Synopsis : An application was found that may use CGI parameters to control sensitive information. Description :

			According to their names, some CGI parameters may control sensitive data (e.g., ID, privileges, commands, prices, credit card data, etc.). In the course of using an application, these variables may disclose sensitive data or be prone to tampering that could result in privilege escalation. These parameters should be examined to determine what type of data is controlled and if it poses a security risk. ** This plugin only reports information that may be useful for auditors ** or pen-testers, not a real flaw. Solution : Ensure sensitive data is not disclosed by CGI parameters. In addition, do not use CGI parameters to control access to resources or privileges. Plugin output : Potentially sensitive parameters for CGI /bugzilla/docs/page.cgi : id : Potential horizontal or vertical privilege escalation Potentially sensitive parameters for CGI /bugzilla/page.cgi : id : Potential horizontal or vertical privilege escalation
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 33817 Synopsis : Load estimation for web application tests. Description : This script computes the maximum number of requests that would be done by the generic web tests, depending on miscellaneous options. It does not perform any test by itself. The results can be used to estimate the duration of these tests, or the complexity of additional manual tests. Note that the script does not try to compute this duration based on external factors such as the network and web servers loads. Solution : n/a Plugin output : Here are the estimated number of requests in miscellaneous modes

for one method only (GET or POST) :

[Single / Some Pairs / All Pairs / Some Combinations / All Combinations]

on site request forgery	: S=10	SP=10	AP=10	SC=10	AC=10
SQL injection	: S=1260	SP=4284	AP=4284	SC=7896	AC=7896
unseen parameters	: S=1575	SP=5355	AP=5355	SC=9870	AC=9870
local file inclusion	: S=45	SP=153	AP=153	SC=282	AC=282
XML injection	: S=45	SP=153	AP=153	SC=282	AC=282
web code injection	: S=45	SP=153	AP=153	SC=282	AC=282
format string	: S=90	SP=306	AP=306	SC=564	AC=564
script injection	: S=10	SP=10	AP=10	SC=10	AC=10
injectable parameter	: S=90	SP=306	AP=306	SC=564	AC=564
cross-site scripting (comprehensive test)	: S=180	SP=612	AP=612	SC=1128	AC=1128
cross-site scripting (extended patterns)	: S=60	SP=60	AP=60	SC=60	AC=60
directory traversal (write access)	: S=90	SP=306	AP=306	SC=564	AC=564
SSI injection	: S=135	SP=459	AP=459	SC=846	AC=846
header injection	: S=20	SP=20	AP=20	SC=20	AC=20
HTML injection	: S=50	SP=50	AP=50	SC=50	AC=50
directory traversal	: S=1305	SP=4437	AP=4437	SC=8178	AC=8178
arbitrary command execution (time based)	: S=270	SP=918	AP=918	SC=1692	AC=1692
persistent XSS	: S=180	SP=612	AP=612	SC=1128	AC=1128
SQL injection (2nd order)	: S=45	SP=153	AP=153	SC=282	AC=282
directory traversal (extended test)	: S=2295	SP=7803	AP=7803	SC=14382	AC=14382
arbitrary command execution	: S=990	SP=3366	AP=3366	SC=6204	AC=6204
blind SQL injection (4 requests)	: S=180	SP=612	AP=612	SC=1128	AC=1128
HTTP response splitting	: S=90	SP=90	AP=90	SC=90	AC=90
blind SQL injection	: S=1350	SP=4590	AP=4590	SC=8460	AC=8460
All tests	: S=10410	SP=34818	AP=34818	SC=63972	AC=63972

Here are the estimated number of requests in miscellaneous modes

for both methods (GET and POST) :

[Single / Some Pairs / All Pairs / Some Combinations / All Combinations]

on site request forgery	: S=20	SP=20	AP=20	SC=20	AC=20
SQL injection	: S=2520	SP=8568	AP=8568	SC=15792	AC=15792
unseen parameters	: S=3150	SP=10710	AP=10710	SC=19740	AC=19740
local file inclusion	: S=90	SP=306	AP=306	SC=564	AC=564
XML injection	: S=90	SP=306	AP=306	SC=564	AC=564
web code injection	: S=90	SP=306	AP=306	SC=564	AC=564
format string	: S=180	SP=612	AP=612	SC=1128	AC=1128
script injection	: S=20	SP=20	AP=20	SC=20	AC=20
injectable parameter	: S=180	SP=612	AP=612	SC=1128	AC=1128
cross-site scripting (comprehensive test)	: S=360	SP=1224	AP=1224	SC=2256	AC=2256
cross-site scripting (extended patterns)	: S=120	SP=120	AP=120	SC=120	AC=120
directory traversal (write access)	: S=180	SP=612	AP=612	SC=1128	AC=1128
SSI injection	: S=270	SP=918	AP=918	SC=1692	AC=1692

			header injection : S=40 SP=40 AP=40 SC=40 AC=40 HTML injection : S=100 SP=100 AP=100 SC=100 AC=100 directory traversal : S=2610 SP=8874 AP=8874 SC=16356 AC=16356 arbitrary command execution (time based) : S=540 SP=1836 AP=1836 SC=3384 AC=3384 persistent XSS : S=360 SP=1224 AP=1224 SC=2256 AC=2256 SQL injection (2nd order) : S=90 SP=306 AP=306 SC=564 AC=564 directory traversal (extended test) : S=4590 SP=15606 AP=15606 SC=28764 AC=28764 arbitrary command execution : S=1980 SP=6732 AP=6732 SC=12408 AC=12408 blind SQL injection (4 requests) : S=360 SP=1224 AP=1224 SC=2256 AC=2256 HTTP response splitting : S=180 SP=180 AP=180 SC=180 AC=180 blind SQL injection : S=2700 SP=9180 AP=9180 SC=16920 AC=16920 All tests : S=20820 SP=69636 AP=69636 SC=127944 AC=127944 Your mode : single, GET and POST, experimental tests. Maximum number of requests : 20820
75.126.159.3	Low	Pass	Application: http Port: 80 Protocol: tcp VATID: 39470 Synopsis : Some generic CGI attacks ran out of time. Description : Some generic CGI tests ran out of time during the scan. The results may be incomplete. Solution : Consider increasing the 'maximum run time (min)' preference for the 'Web Application Tests Settings' in order to prevent the CGI scanning from timing out. Less ambitious options could also be used, such as : - Combinations of arguments values = 'all combinations' is much slower than 'two pairs' or 'single'. - Stop at first flaw = 'per port' is quicker. - In 'some pairs' or 'some combinations' mode, try reducing web_app_tests.tested_values_for_each_parameter in nessusd.conf Plugin output : The following tests timed out without finding any flaw : - SQL injection (on HTTP headers) - SQL injection - directory traversal - arbitrary command execution

75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: udp VATID: 10287 Synopsis : It was possible to obtain traceroute information. Description : Makes a traceroute to the remote host. Solution : n/a Plugin output : For your information, here is the traceroute from 38.123.140.114 to 75.126.159.3 : 38.123.140.114 38.123.140.1 38.122.22.61 154.24.24.1 154.54.85.149 154.54.42.89 154.54.41.53 4.68.63.173 4.53.116.66 173.192.18.153 173.192.18.134 173.192.18.213 66.228.118.182 75.126.159.3
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 10180 Synopsis : It was possible to identify the status of the remote host (alive or dead) Description : This plugin attempts to determine if the remote host is alive using one or more ping types : - An ARP ping, provided the host is on the local subnet and Nessus is running over ethernet. - An ICMP ping. - A TCP ping, in which the plugin sends to the remote host a packet with the flag SYN, and the host will reply with

			a RST or a SYN/ACK. - A UDP ping (DNS, RPC, NTP, etc). Solution : n/a Plugin output : The remote host is up The remote host replied to an ICMP echo packet
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 12053 Synopsis : It was possible to resolve the name of the remote host. Description : Nessus was able to resolve the FQDN of the remote host. Solution : n/a Plugin output : 75.126.159.3 resolves as 75.126.159.3-static.reverse.softlayer.com.
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 50350 Synopsis : It was not possible to determine the remote operating system. Description : Using a combination of remote probes (TCP/IP, SMB, HTTP, NTP, SNMP, etc), it was possible to gather one or more fingerprints from the remote system. Unfortunately, though, Nessus does not currently know how to use them to identify the overall system. Solution : n/a Plugin output : If you think these signatures would help us improve OS fingerprinting,

			please send them to : os-signatures@nessus.org Be sure to include a brief description of the device itself, such as the actual operating system or product / model names. HTTP!/:Server: Apache SMTP!/:554 trainpetdoga.com.com ESMTP not accepting messages 550 5.0.0 Command rejected 500 5.5.1 Command unrecognized: ""\n 421 4.3.2 Connection rate limit exceeded.
75.126.159.3	Low	Pass	Application: sunrpc Port: 111 Protocol: udp VATID: 11111 Synopsis : An ONC RPC service is running on the remote host. Description : By sending a DUMP request to the portmapper, it was possible to enumerate the ONC RPC services running on the remote port. Using this information, it is possible to connect and bind to each service by sending an RPC request to the remote port. Solution : n/a Plugin output : The following RPC services are available on UDP port 111 : - program: 100000 (portmapper), version: 4 - program: 100000 (portmapper), version: 3 - program: 100000 (portmapper), version: 2
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: tcp VATID: 45590 Synopsis : It is possible to enumerate CPE names that matched on the remote system. Description : By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

			Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan. See also : http://cpe.mitre.org/ Solution : n/a Plugin output : Following application CPE's matched on the remote system : cpe:/a:mozilla:bugzilla:4.4.2 -> Mozilla Bugzilla 4.4.2 cpe:/a:isc:bind:9
75.126.159.3	Low	Pass	Application: general Port: 0 Protocol: icmp VATID: 10114 Synopsis : It is possible to determine the exact time set on the remote host. Description : The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols. Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time. Solution : Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14). Plugin output : The difference between the local and remote clocks is 2 seconds. CVE : CVE-1999-0524 Other references : OSVDB:94, CWE:200
75.126.159.3	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 14772 Synopsis :

			This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to identify common services which might have been missed because of a network problem. Solution : See below Plugin output : An FTP server is running on this port
75.126.159.3	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 10092 Synopsis : An FTP server is listening on this port. Description : It is possible to obtain the banner of the remote FTP server by connecting to the remote port. Solution : n/a Plugin output : The remote FTP banner is : 220 (vsFTPD 2.3.2)
75.126.159.3	Low	Pass	Application: ftp Port: 21 Protocol: tcp VATID: 52703 Synopsis : An FTP server is listening on the remote port. Description : The remote host is running vsftpd, an FTP server for UNIX-like systems written in C. See also :

			http://vsftpd.beasts.org/ Solution : n/a Plugin output : Source : 220 (vsFTPd 2.3.2) Version : 2.3.2
75.126.159.3	Low	Pass	Application: domain Port: 53 Protocol: udp VATID: 11002 Synopsis : A DNS server is listening on the remote host. Description : The remote service is a Domain Name System (DNS) server, which provides a mapping between hostnames and IP addresses. See also : http://en.wikipedia.org/wiki/Domain_Name_System Solution : Disable this service if it is not needed or restrict access to internal hosts only if the service is available externally.
75.126.159.3	Low	Pass	Application: domain Port: 53 Protocol: udp VATID: 11951 Synopsis : It may be possible to fingerprint the remote DNS server. Description : This script attempts to identify the remote DNS server type and version by sending various invalid requests to the remote DNS server and analyzing the error codes returned. See also : http://cr.yp.to/surveys/dns1.html Solution : n/a

			Plugin output : The remote name server could be fingerprinted as being : ISC BIND 9.8.2
75.126.159.3	Low	Pass	Application: domain Port: 53 Protocol: udp VATID: 35371 Synopsis : The DNS server discloses the remote host name. Description : It is possible to learn the remote host name by querying the remote DNS server for 'hostname.bind' in the CHAOS domain. Solution : It may be possible to disable this feature. Consult the vendor's documentation for more information. Plugin output : The remote host name is : trainpetdoga.com
75.126.159.3	Low	Pass	Application: domain Port: 53 Protocol: tcp VATID: 11002 Synopsis : A DNS server is listening on the remote host. Description : The remote service is a Domain Name System (DNS) server, which provides a mapping between hostnames and IP addresses. See also : http://en.wikipedia.org/wiki/Domain_Name_System Solution : Disable this service if it is not needed or restrict access to internal hosts only if the service is available externally.
75.126.159.3	Low	Pass	Application: sunrpc Port: 111 Protocol: tcp VATID: 53335

			Synopsis : An ONC RPC portmapper is running on the remote host. Description : The RPC portmapper is running on this port. The portmapper allows someone to get the port number of each RPC service running on the remote host by sending either multiple lookup requests or a DUMP request. Solution : n/a
75.126.159.3	Low	Pass	Application: domain Port: 53 Protocol: tcp VATID: 10728 Synopsis : The remote name server can be fingerprinted. Description : It was possible to determine that the remote name server is running BIND 9.x by querying it for the AUTHORS map. Solution : Change the source code to prevent fingerprinting the server.
75.126.159.3	Low	Pass	Application: sunrpc Port: 111 Protocol: tcp VATID: 11111 Synopsis : An ONC RPC service is running on the remote host. Description : By sending a DUMP request to the portmapper, it was possible to enumerate the ONC RPC services running on the remote port. Using this information, it is possible to connect and bind to each service by sending an RPC request to the remote port. Solution : n/a Plugin output : The following RPC services are available on TCP port 111 :

			- program: 100000 (portmapper), version: 4 - program: 100000 (portmapper), version: 3 - program: 100000 (portmapper), version: 2
75.126.159.3	Low	Pass	Application: smtp Port: 25 Protocol: tcp VATID: 14772 Synopsis : This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to identify common services which might have been missed because of a network problem. Solution : See below Plugin output : A SMTP server is running on this port
75.126.159.3	Low	Pass	Application: ntp Port: 123 Protocol: udp VATID: 10884 Synopsis : An NTP server is listening on the remote host. Description : An NTP (Network Time Protocol) server is listening on this port. It provides information about the current date and time of the remote system and may provide system information. Solution : n/a
75.126.159.3	Low	Pass	Application: ndmp Port: 10000 Protocol: tcp VATID: 14772 Synopsis : This plugin performs service detection. Description : This plugin is a complement of find_service1.nasl. It attempts to

			identify common services which might have been missed because of a network problem. Solution : See below Plugin output : A web server is running on this port
--	--	--	--

CONFIDENTIALITY: This email (including any attachments) may contain confidential, proprietary and privileged information. Unauthorized disclosure or use is prohibited. If you received this email in error, please notify the sender and delete this email from your system.